

Abusing LAPS TOC

- Introduction to LAPS

- Overview of Local Administrator Password Solution (LAPS)

- Legacy LAPS vs. Windows LAPS (Native)

- Architecture – How LAPS Stores Passwords in Active Directory

Reconnaissance and Enumeration

- Identifying LAPS Implementation in a Domain

- Enumerating Computer Object with LAPS Attributes Using PowerView

- Determining LAPS Password Expiration Times

Exploiting Domain Misconfigurations

- Reading Passwords via Insufficient Access Control Lists (ACLs)

- Abusing ms-mcs-admpwd and ms-Mcs-AdmPwdExpirationTime Attributes

- Exploiting Insecure ms-ds-machineaccountquota Settings

- Leveraging Authenticated User Permissions to Read Passwords

Post-Exploitation and Attack Vectors

- Reading Local Admin Passwords as a Domain User

- Using LAPS Passwords for Lateral Movement

- Extracting LAPS Settings from the Registry

Advanced Scenarios

- Abusing Azure AD and Intune LAPS Configurations

- Intercepting or Modifying Password Expiration Times

Mitigation and Hardening

- Restricting Read Access to LAPS Attributes

- Auditing Password Reads and Changes

- Upgrading to Windows LAPS (Native)

- Implementing Credential Theft Mitigation Strategies

AS-REP Roasting TOC

PART I: Foundations of AS-REP Roasting

- Chapter 1: Introduction to AS-REP Roasting

 - Discovery and Historical Context

 - AS-REP Roasting vs. Kerberoasting: Key Distinctions

 - Attack Prerequisites and Scope Analysis

- Chapter 2: Kerberos Authentication Protocol

 - AS-REP Request and Response Protocol Deep Dive

 - User Account Properties – DON'T_REQ_PREAUTH Flag

 - Pre-Authentication Bypass Mechanics

 - Encryption Type Selection and Fallbacks

- Chapter 3: AS-REP Roast Attack Anatomy

 - Core Exploitation Workflow

 - Hash Extraction and Structure Analysis

 - Key Derivation Attacks – RC4, HMAC, MD5

 - Success Probability Factors by AD Environment

PART II: Offensive Operations – The Attacker's Arsenal

- Chapter 4: Execution and Harvesting

 - Tool Ecosystem – Impacket Tool Suite, Impacket-GetNPUsers, and

Rubeus

 - Multi-Threaded Enumeration Strategies

 - OPSEC Considerations – Query Rate Limiting

	Hybrid Attack Combinations (AS-REP + Kerberoasting)
Chapter 5: Cracking and Analysis	
	AS-REP Roast Hash Formats and Wordlists
	GPU Cracking Optimization (Hashcat Mode 18200)
	Password Policy Reverse Engineering
	Batch Account Prioritization Models
Chapter 6: Post-Exploitation Impact	
	Direct Service Access with Compromised Credentials
	Lateral Movement from Batch and Legacy Domain Accounts
	Privilege Escalation Pathways
	DCSync and Delegation Abuse
Chapter 7: Advanced Offensive Techniques	
	Cloud AS-REP Roasting Attack on Azure AD Legacy Apps
	Custom Payload Development
	EDR Evasion Tactics
	Automation in C2 Frameworks
PART III – Reconnaissance and Enumeration	
Chapter 8: Reconnaissance and Enumeration	
	Unauthenticated AD Enumeration Techniques
	LDAP Query Filters for DON'T_REQ_PREAUTH
	Netexec, CrackMapExec, and PowerView
	Anonymous Bind Exploitation
	Batch Account Identification Patterns
PART IV – Defensive Strategies – Protection Framework	
Chapter 9: Detection Capabilities	
	Critical Event IDs – 4768, 4771, Failed AS-REQ
	Anomaly Detection – Pre-Auth Bypass Patterns
	Network Monitoring – Port 88 Anomalies
	SIEM Correlation Rules
Chapter 10 – Prevention Engineering	
	Account Configuration Hardening
	Removing DON'T_REQ_PREAUTH Flag
	PowerShell Remediation Scripts
	Legacy Account Cleanup Strategies
	Service Account Segmentation
Chapter 11 – Policy and Access Controls	
	Domain-Wide Pre-Authentication Enforcement
	Protected Users Group Membership
	Fine-Grained Password Policies (FGPP)
	Anonymous LDAP Bind Restrictions
Chapter 12 – Incident Response Procedures	
	Incident Response Timeline and Checklists
	Compromise Account Isolation
	Forensics Artifacts Collection
	Reset and Remediation Protocols
Chapter 13 – Advanced Defensive Architecture	
	Behavioral Analytics Platforms
	Machine Learning (ML) Baselines
	Zero Trust Identity Verification
	Continuous Threat Hunting

PART IV – Technical Implementation

Chapter 14 – Cryptographic Weaknesses

RC4 in AS-REP: Mathematical Vulnerabilities

Hash Format Evolution and Parsing

AES Transition Challenges

Chapter 15 – Platform-Specific Behaviors

Windows 2003 – 2022 Versions Analysis

Samba and Linux Kerberos Behaviors

Hybrid Identity Implications

Chapter 16 – Real-World Case Studies

Breach Post-Mortems Featuring AS-REP Roasting

Penetration Testing Engagements – Common Findings

Blue Team Mitigation Success Metrics

PART V – Practitioner Resources

Chapter 17 – Offensive Implementation Guide

Complete Toolchain Walkthroughs

Bash and PowerShell Script Repository

Wordlist Optimization Strategies

Chapter 18 – Defensive Deployment Guide

GPO Templates and Scripts

Detection Rule Libraries (Sigma, Splunk)

Validation Testing Frameworks

PART VI – Future Threat Landscape

Chapter 19 – Attack Evolution Vectors

New Protocol Weaknesses

Cloud-Native AS-REP Variants

Quantum Resistance Requirements

Chapter 20 – Research Frontiers

Detection Innovation Opportunities

Mitigation Tradeoff Analysis

Chapter 1: Active Directory Fundamentals, Architecture, and Attack Surfaces

Chapter X: Active Directory Fundamentals and Architecture

Chapter X: Reconnaissance and Enumeration Techniques

Chapter X: Kerberos Authentication Attacks

Chapter X: Credential Extraction and Lateral Movement

Chapter X: NTLM and LDAP Relay Attacks

Chapter X: Privilege Escalation and Domain Escalation

Chapter X: Persistence and Backdoor Mechanisms
 Chapter X: Advanced Attack Techniques and Evasion
 Chapter X: Defensive Monitoring and Detection Strategies
 Chapter X: Incident Response and Forensic Analysis
 Chapter X: Red Team, Blue Team, and Purple Team Operations
 Chapter X: Security Assessment Frameworks and Best Practices
 Chapter X: Patch and Vulnerability Management
 Chapter X: Foundations of Active Directory Architecture
 Chapter X: Passive Information Gathering and OSINT
 Chapter X: Network Footprinting and Service Discovery
 Chapter X: Unauthenticated Enumeration Techniques
 Chapter X: Authenticated Enumeration with User Credentials
 Chapter X: Advanced Enumeration and Kerberoasting
 Chapter X: AD Component Footprinting
 Chapter X: Group Policy and Delegation Analysis
 Chapter X: Active Directory Trust Relationships and Multi-Domain Reconnaissance
 Chapter X: BloodHound and Attack Pathway Visualization
 Chapter X: Evasion and OPSEC (Operational Security)
 Chapter X: Defensive Reconnaissance and Hardening
 Chapter X: Active Directory Fundamentals and Attack Surfaces

- 1.
- 2.
3. Foundations (Chapters 1-2): Build knowledge base.
4. Offensive Phases (Chapters 3-8): Detail attacks progressively (recon > exploitation > persistence).
5. Advanced Offense and Evasion (Chapters 9-10): For experienced readers
6. Defensive Countermeasures (Chapters 11-13): Mirror offense with hardening and detection.
7. Operations and Best Practices (Chapters 14-16): Tie it together for real-world application.

This order ensures accessibility (start simple) while escalating complexity, ending with actionable advice. Total: 16 chapters (scalable; merge if needed). Each chapter could include: learning objectives, diagrams (e.g., AD schema), code snippets (PowerShell/Python), ethical routes, and exercises (e.g., lab setups with VirtualBox/AD DS).

Chapter 1: Active Directory Fundamentals, Architecture, and Attack Surface
 (Consolidate proposed Chapter 1 and duplicates like "Foundations of Active Directory Architecture" and "Active Directory Fundamentals and Attack Surfaces." Introduce AD components (domains, forests, trusts), schema, protocols (Kerberos, LDAP, NTLM), and common vectors (e.g., weak delegation). Include hybrid AD basics for context. Why first? Sets the stage without being overwhelming).

Chapter 2: Passive and Active Reconnaissance Techniques
 (Merge "Passive Information Gathering and OSINT," "Network Footprinting and Service Discovery," "Unauthenticated Enumeration Techniques," "Authenticated Enumeration with User Credentials," "Active Directory Trust Relationships and Multi-Domain Reconnaissance," and "AD Component Footprinting." Cover OSINT (e.g., DNS enumeration via dig), unauth scans (e.g., rpcclient), auth recon (e.g., ldapsearch), and tools like Nmap/AdFind. Subsections on trusts and multi-domain recon for depth).

Chapter 3: Advanced Enumeration and Kerberos Attacks

((Combine "Advanced Enumeration and Kerberoasting," "Group Policy and Delegation Analysis," and "Kerberos Authentication Attacks." Dive into Kerberoasting/ASREPROast, GPO enumeration (e.g., via PowerView), and delegation abuse (e.g., unconstrained delegation). Include BloodHound integration here for pathway visualization.)

Chapter 4: Credential Extraction and Lateral Movement

(Direct from your list. Focus on techniques like DCSync, LSASS dumping (Mimikatz), and pass-the-hash/ticket. Cover tools like Rubeus and lateral tools (e.g., CrackMapExec). Emphasize ethical boundaries for credential handling.)

Chapter 5: NTLM and LDAP Relay Attacks

(Unchanged from your list. Detail relay attacks (e.g., Responder, ntlmrelayx), coercion (e.g., PetitPotam), and mitigations like SMB signing. Include hybrid implications for Azure AD Connect.)

Chapter 6: Privilege Escalation and Domain Escalation

(Unchanged. Cover local priv esc (e.g., PrintNightmare), domain admin paths (e.g., golden/silver tickets), and escalation via trusts or shadow creds. Use BloodHound for visualization.)

Chapter 7: Persistence and Backdoor Mechanisms

(Unchanged. Discuss skeletons (e.g., AD CS abuse), golden SAML, and backdoors like rogue GPOs or machine accounts. Tie to hybrid persistence.)

Chapter 8: Advanced Attack Techniques in Hybrid Environments

(New consolidation: Merge "Advanced Attack Techniques and Evasion" with hybrid elements from your recon/escalation topics. Add coverage of Azure AD/Entra ID attacks (e.g., app registrations, PIM bypass), as this is a gap. Include cloud-AD sync attacks like PSEXec over Azure.)

Chapter 9: Evasion and Operational Security (OPSEC)

(From your list: "Evasion and OPSEC." Cover AMSI bypass, ETW patching, living-off-the-land (e.g., PS remoting), and AD-specific evasion (e.g., avoiding Event ID 4769 logs). Emphasize ethical OPSEC for pentesters.)

Chapter 10: BloodHound and Attack Pathway Visualization

(Pulled up from your list for mid-offense placement. Dedicated chapter on BloodHound/SharpHound for graphing AD paths, with custom queries and defensive uses. This acts as a "toolkit" chapter.)

Chapter 11: Defensive Monitoring and Detection Strategies

(Unchanged, but expanded. Mirror offensive chapters: e.g., detect Kerberoasting via 4769 events, use Microsoft Defender for Identity (MDI), and SIEM rules (Splunk/ELK). Include "Defensive Reconnaissance and Hardening" elements like ACL audits.)

Chapter 12: Incident Response and Forensic Analysis

(Unchanged. Cover AD IR (e.g., timeline analysis with DSInternals), forensics tools (e.g., Autopsy for event logs), and playbooks for breaches like DCSync.)

Chapter 13: Hardening Active Directory and Patch Management

(Merge "Patch and Vulnerability Management" with hardening from your defensive recon. Detail baselines (e.g., Tier 0 isolation), patching (e.g., for Zerologon), and tools like LAPS or Just Enough Admin (JEA).)

Chapter 14: Red Team, Blue Team, and Purple Team Operations

(Unchanged. Practical exercises: Simulate attacks with Atomic Red Team, blue team hunts, and purple team workshops. Include scoring matrices for AD assessments.)

Chapter 15: Security Assessment Frameworks and Best Practices

(Unchanged, but add ethical/legal sections: OSCP-style reporting, compliance (e.g., CIS Controls for AD), and best practices (e.g., zero-trust AD via BeyondCorp).)

Chapter 16: Case Studies, Emerging Threats, and Future Directions

(New addition: Wrap with real-world cases (e.g., NotPetya AD exploitation, SolarWinds hybrid breach), emerging topics (e.g., AI-driven AD attacks, quantum-resistant Kerberos), and resources (tools repo, labs). This provides closure and Springer-friendly forward-thinking.)

PART I – WHY FEDERAL ACTIVE DIRECTORY DOMAINS AND NETWORKS ARE DIFFERENT

CHAPTER 1. THE CASE FOR FEDERAL ACTIVE DIRECTORY FICAM DOMAINS AND NETWORKS

CHAPTER PURPOSE

This chapter establishes the need for a specialized approach to securing, assessing, defending, and hunting threats within federal Active Directory environments. It introduces the concepts of Federal Identity, Credential, and Access Management (FICAM), explains why Active Directory remains a critical component of federal identity infrastructure, and demonstrates how Command mission assurance, compliance requirements, and advanced threat actors have transformed identity systems into high-value operational targets.

CHAPTER ABSTRACT

For more than two decades, Microsoft Active Directory has served as the identity foundation for government agencies, military branches and organizations, defense contractors, intelligence communities (ICs), and civilian federal enterprises. While numerous publications have examined Active Directory administration, security, and penetration testing, few have addressed the unique operational realities of federal federate identity infrastructures where Active Directory functions as only one component within a larger Federal Identity, Credential, and Access Management (FICAM) ecosystem.

Federal Active Directory environments differ significantly from commercial enterprise deployments. Identity systems within federal NIPRNet and SIPRNet networks must support Risk Management Framework (RMF) requirements, Federal Information Security Modernization Act (FISMA) mandates, NIST digital identity guidance, Public Key Infrastructure (PKI) trust architectures, Common Access Card (CAC) and Personal Identity Verification (PIV) authentication systems, continuous logging and monitoring programs, and mission assurance objectives. Consequently, attacks against Active Directory are no longer just limited to unauthorized access, privilege escalation, or lateral movement; they increasingly represent threats to operational readiness, mission execution, and national security objectives and initiatives. This chapter introduces readers to the foundational concepts that are necessary for understanding federal identity systems and establishes the framework through which offensive security practitioners, defenders, assessors, and security engineers should evaluate Active Directory environments. Readers will examine the evolution of federal identity architecture, explore the relationship between Active Directory and FICAM, analyze common misconceptions regarding federal directory services, and understand why modern adversaries are increasingly targeting identity infrastructures rather than traditional network perimeters.

LEARNING OBJECTIVES

Upon completion of this chapter, readers will be able to:

- Differentiate between commercial Active Directory deployments and federal

Active Directory environments.

- Explain the purpose and objectives of Federal Identity, Credential, and Access Management (FICAM).
- Describe the role of Active Directory within federal identity ecosystems.
- Understand how identity systems support mission assurance and operational readiness.
- Recognize why modern adversaries target identity infrastructures.
- Explain the relationship between Active Directory, PKI, federation services, and federal identity programs.
- Identify key stakeholders responsible for federal identity security.
- Understand how offensive and defensive security operations intersect with identity management objectives.

CHAPTER STRUCTURE

1.1 Why This Handbook Exists

1.1.1 The Evolution of Active Directory Security Infrastructure

1.1.2 The Gap Between Commercial Active Directory and Federal Active Directory

1.1.3 Why Existing Active Directory Books Do Not Fully Address FICAM

1.1.4 The Need for an Identity-Centric Security Perspective

1.1.5 Defining the Target Audience

1.2 Understanding Federal Identity, Credential, and Access Management (FICAM)

1.2.1 Origins of Federal Identity Management Programs

1.2.2 Identity Management Components

1.2.3 Credential Management Components

1.2.4 Access Management Components

1.2.5 Federation Services and Trust Relationships

1.2.6 FICAM as a Mission Enabler

1.3 Active Directory's Role Within Federal Identity Ecosystems

1.3.1 Active Directory as an Identity Provider (IdP)

1.3.2 Active Directory as an Authorization Platform

1.3.3 Active Directory as an Enterprise Trust Anchor

1.3.4 Integration with PKI and Smart Card Authentication

1.3.5 Integration with Cloud Identity Providers (CIAP)

1.3.6 Active Directory's Continuing Relevance in Zero Trust Network

Architecture (ZTNA)

1.4 Commercial Active Directory Versus Federal Active Directory

1.4.1 Business Objectives Versus Mission Objectives

1.4.2 Risk Tolerance Differences

1.4.3 Compliance Requirements and Regulatory Drivers

1.4.4 CAC, PIV, and Smart Card Authentication Requirements

1.4.5 RMF, STIG, and Continuous Monitoring (ConMon) Expectations

1.4.6 Command Operational Readiness Versus Business Continuity

1.4.7 Case Comparison: Commercial Enterprise Domain Versus Federal

Enterprise Domain

1.5 Active Directory as High-Value Cyber Terrain

1.5.1 Why Attackers Target Identity Systems

1.5.2 The Evolution from Network-Centric to Identity-Centric Attacks

1.5.3 Credential Theft as an Operational Objective

1.5.4 Privilege Escalation and Identity Dominance

1.5.5 Identity Infrastructure as a Pathway to Mission Disruption

1.5.6 Active Directory as a Strategic Target for Nation-State Adversaries

(Advanced Persistent Threat – APT)

- 1.6 Understanding the Federal Identity Attack Surface
 - 1.6.1 Active Directory Domain Services (AD DS)
 - 1.6.2 Active Directory Certificate Services (AD CS)
 - 1.6.3 Active Directory Federation Services (AD FS)
 - 1.6.4 Microsoft Entra ID and Hybrid Identity Components
 - 1.6.5 Public Key Infrastructure (PKI)
 - 1.6.6 Trust Relationships
 - 1.6.7 Administrative Workstations and Privileged Access Systems
 - 1.6.8 Identity Synchronization Services
- 1.7 Stakeholders Responsible for Federal Identity Security
 - 1.7.1 Authorizing Officials (AOs)
 - 1.7.2 System Owners
 - 1.7.3 ISSMs and ISSOs
 - 1.7.4 Active Directory Engineers
 - 1.7.5 Cybersecurity Service Providers
 - 1.7.6 Security Control Assessors (SCAs)
 - 1.7.7 Red Teams, Purple Teams, Blue Teams
- 1.8 Offensive and Defensive Perspectives of Federal Active Directory Security
 - 1.8.1 How Attackers View Federal Identity Infrastructure
 - 1.8.2 How Defenders View Federal Identity Infrastructure
 - 1.8.3 How Assessors Evaluate Federal Identity Risk
 - 1.8.4 Bridging Offensive Findings and Defensive Improvements
 - 1.8.5 The Importance of Breach & Adversary Simulation (BAS)
- 1.9 The Future of Federal Identity Systems
 - 1.9.1 Zero Trust Network Architecture (ZTNA)
 - 1.9.2 Passwordless Authentication
 - 1.9.3 FIDO2 and Phishing-Resistant MFA
 - 1.9.4 Hybrid Identity Architecture
 - 1.9.5 Cloud-Native Identity Services
 - 1.9.6 Identity as the New Security Perimeter
- 1.10 Case Study: Compromise of a Federal Identity Infrastructure
 - 1.10.1 Initial Access
 - 1.10.2 Credential Theft
 - 1.10.3 Active Directory Enumeration
 - 1.10.4 Privilege Escalation
 - 1.10.5 Federation Abuse
 - 1.10.6 Mission Impact
 - 1.10.7 Detection Opportunities
 - 1.10.8 Lessons Learned

INCLUDED FIGURES

- Figure 1-1. Evolution of Federal Identity Architecture
- Figure 1-2. Components of a Federal FICAM Ecosystem
- Figure 1-3. Commercial Active Directory Versus Federal Active Directory
- Figure 1-4. Federal Identity Attack Surface
- Figure 1-5. Identity-Centric Attack Lifecycle
- Figure 1-6. Stakeholders in Federal Identity Security
- 1.1 Why Commercial Active Directory Guidance Is Not Enough
- 1.2 Federal Enterprise Identity as Mission-Critical Infrastructure
- 1.3 Traditional IAM vs. Federal ICAM vs. FICAM

- 1.4 Active Directory as the Operational Core of Federal Identity Posture
- 1.5 Mission Risk, Authorization Risk, and Adversarial Risk
- 1.6 How Attackers and Offensive Security Professionals Exploit Identity-Centric Federal Environments
- 1.7 How Enterprise Defenders Translate Active Directory (AD) Risk into RMF, POA&M, and Mission Language
- 1.8 Intended Audience: Newcomers, Operators, Ethical Hackers, Engineers, Security Assessors and Auditors, Red, Purple, and Blue Teams
- 1.9 Handbook Methodology: Offensive Tradecraft, Defensive Security Engineering, and Federally Mandated Compliance
- 1.10 Case Study: When a Domain Compromise Becomes a Mission Assurance Problem

- o What is Hacktivism?
- o List the different types of hacker classes
- o Define the skills required to become an ethical hacker
- o What is Vulnerability Research?
- o Describe the ways of conducting ethical hacking
- o Understand Local and Federal Laws

-
- Key Terms
- Introduction to Ethical Hacking
- Overview of Ethics
- Importance of Security
- o Threats and Vulnerabilities
- o Cyber Attacks
- o Security Breaches
- o Exposure
- Components of Information Security
- o Elements of Information Security
- o Authentication, Authorization, Accountability (AAA)
- o Reusability
- o The Security, Functionality and Ease of Use Triangle
- o The CIA Triad
- o The Parkerian Hexad
- o Defense-in-Depth/Defense-in-Breadth
- Information Security Policies and Procedures
- Core Information Security Principles
- o Security Objectives
- o Risks, Assets, Threats, and Vulnerabilities
- o Data Backup and Recovery
- o Exploit Definition
- o Risk Evaluation
- Overview of Ethical Hacking
- Ethical Hackers vs. Unethical Hackers
- Importance and Benefits of Ethical Hacking
- History and Evolution of Hacker Classes and Hacking
- o Hackers and Crackers
- o Hacker Traits and Profiles
- o Types of Hackers
- Attack and Threat Modeling

- o Cyber Kill Chain (CKC) Methodology
- o MITRE ATT&CK Framework
- o MITRE D3F3ND Framework
- Phases of Common Cyber Attacks
- Methodology of Ethical Hacking
- Attack Modeling
- o Phase 1 - Reconnaissance/Information Gathering/Footprinting
- o Phase 2 - Network Scanning
- o Phase 3 - Enumeration
- o Phase 4 - Gaining Initial Access
- o Phase 5 - Maintaining Access (Foothold) and Persistence
- o Phase 6 - Privilege Escalation, Lateral Movement, and Pivoting
- o Phase 7 - Exploitation and Post-Exploitation
- o Phase 8 - Covering Tracks/Clean Up and Exit Strategy
- Types of Ethical Hacking Security Testing
- o Test Planning and Legal Considerations
- ? The Scope and the Questionnaire
- ? Success Criteria
- ? Defining a Non-Disclosure Agreement (NDA)
- ? Obtaining Authorization and Consent (Get Out of Jail Free Card)
- ? Rules of Engagement (ROE)
- ? Ethical Hacking Deliverables (Summary, Documentation)
- o Black Box Testing (No-Knowledge)
- o Gray Box Testing (Partial-Knowledge)
- o White Box Testing (Full-Knowledge)
- o Security Assessments and Audit Types
- Types of Hacker Attacks
- o Operating System (OS) Attacks
- o Application-Level Attacks
- o Shrink-Wrap Code Attacks
- o Misconfiguration Attacks
- Hacktivism
- o Categorization of Hacker Types and Classes
- Ethical Hackers
- o What Do Ethical Hackers Do?
- ? What Can You Do Legally?
- ? Laws of the Land
- ? Is Port Scanning Legal?
- o Can Hacking Be Ethical?
- KSAs (Knowledge, Skills, Abilities) of an Ethical Hacker
- ? Key Skills for Ethical Hackers
- ? Relevant Laws and Guidelines
- What is Vulnerability Research?
- o Why Hackers Need Vulnerability Research, Analysis, and Assessment
- o Vulnerability and Exploit Key Websites of Interest
- Conducting Ethical Hacking
- o How Do They Go About It?
- o Approaches to Ethical Hacking
- o Ethical Hacking Testing
- o Ethical Hacking Deliverables

- Computer Crimes and Implications
- Ethics and Legalities
- o U.S. Federal Law Overview
- o Compliance and Regulatory Bodies
- o Payment Card Industry Data Security Standard (PCI DSS)
- o Health Insurance Portability and Accountability Act (HIPAA)
- o Sarbanes-Oxley (SOX)
- o General Data Protection Regulation (GDPR)
- Legal Perspective (U.S. Federal Law)
- Section 1029 and Penalties
- Section 1030 and Penalties
- Japan Cyber Laws
- United Kingdom (UK) Cyber Laws
- Australia Cyber Laws
- Germany Cyber Laws
- Singapore Cyber Laws
- Chapter Summary
- Recommended Reading and Resources

Add files or folders here
/media/insert-embed/dropbox

Chapter 2. THE RULES: Federal Cybersecurity Governance and Authority Landscape

- 2.1 FISMA and Federal System Information Security Requirements
- 2.2 Department of Defense (DoD) Cybersecurity Policy and Mission Assurance
- 2.3 NIST SP 800-53, Security and Privacy Controls
- 2.4 NIST SP 800-37, Revision 2, Risk Management Framework (RMF for DoD)
- 2.5 NIST SP 800-63, Digital Identity Guidelines
- 2.6 Office of Management and Budget (OMB) Identity and Zero Trust Directives
- 2.7 CNSSI and National Security Systems (NSS)
- 2.8 FedRAMP and Cloud Authorization Boundaries
- 2.9 CMMC and Defense Industrial Base (DIB) Requirements
- 2.10 DoD CIO, DISA, JFHQ-DoDIN, USCYBERCOMMAND, and Command Component Roles and Responsibilities
- 2.11 Case Study: Translating an Active Directory (AD) Weakness Into Federal Control Impact

Chapter 3. Risk Management Framework (RMF) for Active Directory and FICAM Information Systems

- 3.1 RMF Step 1: Categorize Active Directory-Integrated Information Systems
- 3.2 RMF Step 2: Select Security Controls for Identity and Directory Services
- 3.3 RMF Step 3: Implement Active Directory Security Controls
- 3.4 RMF Step 4: Assess Active Directory Security Control Effectiveness
- 3.5 RMF Step 5: System Authorization
- 3.6 RMF Step 6: Continuous Monitoring (ConMon)
- 3.7 Subordinate Command Control Inheritance in Federal Active Directory
- 3.8 Common Control Criteria (CCC), Hybrid Controls, and System-Specific Controls
- 3.9 Security Control Assessor Expectations
- 3.10 Authorization and Perimeter Boundary Challenges with Shared Active Directory (AD) Forests
- 3.11 Plan of Action and Milestone (POA&M) Creation for Discovered Active Directory

Vulnerabilities Tracking and Accountability

3.12 Risk Acceptance, Risk Transference, and Mission Owner Decisions

3.13 Case Study: Kerberos Authentication Protocol Misconfigurations as an RMF Mandatory Remediation: No 'If's', No 'And's,' and No 'But's'

Chapter 4. Host, Asset and Vulnerability Discovery Scanning for Active Directory Domains and Networks

- 4.1 Introduction to Network Scanning
- 4.2 Network Scanning Defined
- 4.3 Objectives of Network Scanning
- 4.4 Host Discovery
- 4.5 ICMP-Based Methods
 - 4.5.1 TCP-Based Methods
 - 4.5.2 UDP-Based Methods
 - 4.5.3 Port Scanning
 - 4.5.3.1 TCP Port Scanning
 - 4.5.3.2 UDP Port Scanning
- 4.6 Service Version Detection
- 4.7 Operating System (OS) Fingerprinting
- 4.8 Network Scanning Methodology
 - 4.8.1 Step 1: Checking for Live Hosts
 - 4.8.2 Step 2: Checking for Listening/Open Ports
 - 4.8.3 Step 3: Fingerprinting the OS (Operating System)
 - 4.8.4 Step 4: Network Vulnerability Scanning
 - 4.8.5 Step 5: Network Probing
- 4.9 Anonymous Web Surfing
- 4.10 Malicious Network Scanning Countermeasures
- 4.11 Network Scanning Tools
 - 4.11.1 Live System Scanning Tools
 - 4.11.2 Port Scanning Tools
 - 4.11.3 War Dialing Tools
 - 4.11.4 Banner Grabbing Tools
 - 4.11.5 Tools for Active Stack Fingerprinting
 - 4.11.6 File Extension Obfuscation/Concealment Tools
 - 4.11.7 Vulnerability Scanning Tools
 - 4.11.8 Network Mappers
 - 4.11.9 Proxies
 - 4.11.10 Anonymizer Tools
 - 4.11.11 Spoofing Tools
- 4.12 Chapter Summary
- 4.13 Recommended Reading and Resources

Chapter 4. YOUR POCKET GUIDES: STIGs, SRGs, and Adherence to Federal Mandated Compliance Application and Implementation of Federally Regulated Mandatory Secure DoDIN and DoD GIG: Configuration and Enclave Hardening Recommendations

- 4.1 4.1 DISA STIGs and Security Requirements Guides
- 4.2 Windows Server STIGs for Domain Controllers
- 4.3 Active Directory Domain STIG Concepts
- 4.4 Microsoft Defender, Windows Firewall, and Endpoint STIG Alignment

- 4.5 CAT I, CAT II, and CAT III Findings
- 4.6 Open Findings, Not Reviewed Findings, Not Applicable Findings
- 4.7 Vulnerability Discussion, Check Text, Fix Text, and Evidence
- 4.8 STIG Viewer, XCCDF, CKL Files, and Automation
- 4.9 Gold Disk, SCC, SCAP, and Automated Compliance Validation
- 4.10 ACAS, Nessus, and Vulnerability Evidence Correlation
- 4.11 STIG Findings vs. Operational Risk
- 4.12 Case Study: CAT I Domain Controller Finding and Mission Impact

Learn various enumeration techniques, such as Border Gateway Protocol (BGP) and Network File Sharing (NFS) exploits, plus associated countermeasures.

- 5 Objectives
 - 5.1 Understand Enumeration
 - 5.2 Understand Null Sessions
 - 5.3 Identifying Types of Enumeration Attacks
 - 5.4 Learn the Steps Involved in Performing Enumeration Against a Target
- 6 Key Terms
- 7 Enumeration Methodolgy
- 8 Introduction to Enumeration
 - 8.1 Protection Rings
 - 8.2 Windows Architecture
 - 8.3 Windows Security Elements
 - 8.3.1 Security Attributes Manager (SAM) Database
 - 8.3.2 Local Security Authority Subsystem Service (LSASS)
 - 8.3.3 NetBIOS (Network Basic Input/Output System)
 - 8.3.4 Active Directory (AD)
- 9 Enumeration Defined
- 10 Enumerating Techniques for Windows Operating System
 - 10.1 NetBIOS Basics
 - 10.2 NetBIOS Enumeration
 - 10.2.1 NetView
 - 10.2.2 NBTSTAT
 - 10.2.3 Nbtscan
 - 10.2.4 User2sid and Sid2user
 - 10.3 NetBIOS Null Sessions
 - 10.4 NetBIOS Enumeration Tools
 - 10.5 Additional Enumeration Tools
- 11 Enumerating *nix Operating System
 - 11.1 *nix Enumeration
- 12 Passive Enumeration
- 13 Active Enumeration
 - 13.1 SNMP Enumeration
 - 13.1.1 SNMPutil
 - 13.1.2 Other SNMP Enumeration Tools
- 14 Enumeration Techniques
 - 14.1 Null Session Enumeration
 - 14.2 SNMP Enumeration
 - 14.3 UNIX Enumeration
 - 14.4 NFS Enumeration
 - 14.5 RPC Enumeration

- 14.6 FTP Enumeration
- 14.7 LDAP Enumeration
 - 14.7.1 Active Directory (AD) Enumeration
- 14.8 SMTP Enumeration
- 14.9 Web Enumeration
- 14.10 Web Application Directory Enumeration
- 14.11 Default Password Enumeration
- 14.12 Service Enumeration
 - 14.12.1 Countermeasures
- 14.13 Remote Procedure Calls (RPCs)
 - 14.13.1 SunRPC
 - 14.13.2 Remote Method Invocation
- 14.14 Server Message Block (SMB)
 - 14.14.1 Built-in Utilities
 - 14.14.2 Nmap Scripts (NSE)
 - 14.14.3 NetBIOS Enumerator
 - 14.14.4 Metasploit
 - 14.14.5 Other Utilities
- 14.15 Simple Network Management Protocol (SNMP)
 - 14.15.1 Countermeasures
- 14.16 Simple Mail Transfer Protocol (SMTP)
 - 14.16.1 Countermeasures
- 14.17 Web-Based Enumeration
 - 14.17.1 Countermeasures
- 15 Domain Name Service (DNS) Zone Transfers
- 16 Enumeration Tools
 - 16.1 Null Session Tools
 - 16.1.1 Null Session Countermeasure Tools
 - 16.2 User Account Tools
 - 16.3 SNMP Enumeration Tools
 - 16.4 LDAP Enumeration Tools
 - 16.5 SMTP Enumeration Tools
 - 16.6 General Enumeration Tools
- 17 Countermeasures
 - 17.1 NetBIOS Null Sessions
 - 17.2 SNMP Enumeration Countermeasures
 - 17.3 DNS Zone Transfer Countermeasures
- 18 Chapter Summary
- 19 Recommended Reading and Resources

Add files or folders here
/media/insert-embed/dropbox

Chapter 5. THEFUNBEGINS: CCRI, CORA, CSSP, and Operational Readiness Assessments

- 5.1 From Compliance Inspection to Operational Readiness
- 5.2 Command Cyber Readiness Inspection Concepts
- 5.3 Cyber Operational Readiness Assessment Concepts
- 5.4 CSSP Visibility into AD Security Events
- 5.5 DODIN Operations and Defensive Cyber Operations
- 5.6 Boundary Defense, Endpoint Defense, and Identity Defense
- 5.7 Active Directory (AD) Certification & Accreditation (CAP) / Assessment &

Authorization (A&A) Packages for Readiness Reviews and Authority to Operate (ATO) Certification

5.8 Vulnerability Tracking Compliance of CAT I and CAT II Remediation Lifecycle Aging, Service-Level Agreements (SLA) Tracking, and Remediation Timelines via POA&M

5.9 Chain of Command Reporting to Leadership

5.10 Commercial Active Directory vs. Federal Active Directory Security Vulnerability Differences / Findings in Federal Assessments

5.11 Case Study: Preparing an AD Forest for CORA-Style Review Objectives

20 Key Terms

21 Introduction to Penetration Testing

22 Definition and Purpose

23 Risk Assessment and Impact Analysis

24 Types and Categories of Penetration Testing

24.1 White Box

24.2 Gray Box

24.3 Black Box

24.4 Hybrid

25 Methodologies and Standards

25.1 The Open Source Security Testing Methodology Manual (OSSTMM)

25.2 Penetration Testing Execution Standard (PTES)

25.3 Technical Guide to Information Security Testing and Assessment by the NIST (National Institute of Standards and Technology)

25.4 The Penetration Testing Framework

25.5 Open Web Application Security Project (OWASP) Testing Guide

26 Phases of Penetration Testing

26.1 Best Practices

26.2 Phase 1 - Planning

26.3 Phase 2 - Preattack

26.4 Phase 3 - Attack

26.5 Phase 4 - Postattack

26.5.1 Postattack Planning Phase

26.6 Phase 5 - Enumeration

26.6.1 Enumeration Preattack Phase

26.6.2 Enumeration Attack Phase

26.6.3 Enumeration Postattack Phase

26.7 Tools

26.7.1 Choosing Different Types of Pentest Tools

26.7.2 Penetration Testing Tools

26.7.3 Other Useful Penetration Testing Tools

27 Chapter Summary

28 Recommended Reading and Resources

Add files or folders here

/media/insert-embed/dropbox

Chapter 6. eMASS, CA&P / A&A Packages, and Active Directory Vulnerability Evidence and Artifact Management

6.1 eMASS System Records and Authorization Boundaries

6.2 System Security Plan (SSP) for AD-Integrated Systems

6.3 Security Control Implementation Statements for Identity Controls

6.4 Artifacts, Evidence, and Assessment Procedures

- 6.5 POA&M Management for Active Directory Vulnerability Tracking and Command Accountability
- 6.6 Continuous Monitoring Submissions
- 6.7 Subordinate Command Inherited Controls
- 6.8 Documenting Trust Relationships and Privileged Access
- 6.9 Mapping STIG, ACAS, Audit, and Manual Findings
- 6.10 Case Study: eMASS Evidence Artifacts for Kerberos Hardening

PART II: NETWORK, WINDOWS, AND IDENTITY FOUNDATIONS

Chapter 7. TCP/IP and Enterprise Network Fundamentals for Active Directory(AD) Security

- 7.1 Open Standards Interconnection (OSI) Reference Model and Transmission Control Protocol/Internet Protocol (TCP/IP) Models for Security Engineers
- 7.2 IPv4, IPv6, Subnetting, and Routing
- 7.3 TCP, UDP, ICMP, and Common Active Directory Ports, Protocols, and Services (PPS)
- 7.4 DNS, DHCP, NTP, SMB, RPC, LDAP, and Kerberos Network Traffic
- 7.5 Virtual Local Area Networks (VLANs), Network Segmentation, Enclaves, and Security Zones (Boundary/Perimeter/Edge)
- 7.6 Firewalls, ACLs, and East-West Traffic Control
- 7.7 Virtual Private Network (VPN), Remote Access, and Privileged Access Pathways
- 7.8 Packet Capture (PCAP) Basics for Active Directory (AD) Authentication Troubleshooting

- 7.9 Case Study: Firewall Rules Breaking Kerberos and Domain Replication

Chapter 8. Windows Security Architecture Fundamentals

- 8.1 Windows Logon Architecture
- 8.2 LSASS and Credentialed Material
- 8.3 Security Identifiers (SIDs) and Relative Identifiers (RIDs)
- 8.4 Access Tokens and Privilege Assignments
- 8.5 ACLs, ACEs, DACLS, and SACLs
- 8.6 Local Security Accounts Manager (SAM), Local Security Authority (LSA) Secrets, Data Protection API (DPAPI), and Credential Storage
- 8.7 Windows Services and Service Control Manager
- 8.8 Event Logs and Audit Policy Configuration Best Practices
- 8.9 Case Study: Token Abuse from Local Admin to Domain Impact

Chapter 9. NTLM Authentication

- 9.1 LM, NTLM, NTLMv1, and NTLMv2
- 9.2 Challenge-Response Authentication
- 9.3 NTLM Hashes and Why Hashes Become Password Equivalents
- 9.4 Pass-the-Hash (PtH) Concepts
- 9.5 NTLM Relay Concepts
- 9.6 Server Message Block (SMB) Signing and Lightweight Directory Access Protocol (LDAP) Signing
- 9.7 NTLM Restrictions in Federal Environments
- 9.8 Detecting NTLM Downgrade Attacks and Excessive NTLM Use
- 9.9 Migration Strategy Away From NTLM
- 9.10 Case Study: NTLM Relay Attack Against LDAP in a Misconfigured Domain

Chapter 10. Kerberos Authentication Protocol

- 10.1 Why Kerberos Replaced NTLM

- 10.2 Kerberos Principals, Realms, and Key Distribution Centers (KDCs)
- 10.3 AS-REQ as AS-REP
- 10.4 TGTs, TGS Tickets, and Service Access
- 10.5 PAC Data and Group Membership Claims
- 10.6 SPNs and Service Account Identity
- 10.7 Encryption Types and Kerberos Hardening
- 10.8 Ticket Lifetimes, Renewal, and Delegation
- 10.9 Kerberos Across Forest Trusts
- 10.10 Kerberos Failure Modes
- 10.11 Detecting Kerberos Abuse
- 10.12 Case Study: Kerberoasting in a Federal Service Account Model
- Chapter 11. NTLM vs. Kerberos in Federal Active Directory Environments
 - 11.1 Authentication Flow Comparison
 - 11.2 Security Properties Comparison
 - 11.3 Operational Compatibility and Legacy Dependencies
 - 11.4 Why NTLM Persists in Federal Networks
 - 11.5 Kerberos Advantages and Misconfiguration Risks
 - 11.6 Application Compatibility Penetration Testing
 - 11.7 Auditing Strategy for NTLM Reduction
 - 11.8 Policy Roadmap for Kerberos-First Authentication (Kerberos Armoring)
 - 11.9 Case Study: Breaking an Application by Disabling NTLM Too Quickly
- Chapter 12. LLMNR, NBT-NS, WPAD, and Name Resolution Abuse
 - 12.1 Windows Name Resolution Order
 - 12.2 LLMNR and NBT-NS Behaviors
 - 12.3 WPAD and Proxy Auto-Discovery Risks
 - 12.4 Poisoning Attacks and Credential Capture
 - 12.5 Responder, Inveigh, and Common Hacking Tools
 - 12.6 Federal Security Baseline Expectations
 - 12.7 Group Policy Mitigation Best Practices
 - 12.8 Detection and Event Correlation
 - 12.9 Case Study: Captured NTLMv2 Hashes From Name Resolution Poisoning Attack

PART III – ACTIVE DIRECTORY ARCHITECTURE FOR FEDERAL ENTERPRISES

- Chapter 13. Active Directory Concepts and Terminology
 - 13.1 Directory Services and LDAP
 - 13.2 Domains, Trees, and Forests
 - 13.3 Organizational Units (OUs) and Containers
 - 13.4 Schema and Configuration Partitions
 - 13.5 Global Catalog Servers (GCS)
 - 13.6 Domain Controllers (DCs), RODCs, and ePDCs
 - 13.7 Domain Trusts and Transitive Authentication
 - 13.8 Case Study: Confusing OU Delegation with Security Boundary
- Chapter 14. Logical vs. Physical Active Directory Design
 - 14.1 Logical Components: Forests, Domains, OUs, Objects, GPOs
 - 14.2 Physical Components: Sites, Subnets, DCs, GCSs, Replication Links
 - 14.3 Federal Enclaves and Mission Boundaries
 - 14.4 Enterprise vs. Component Forest Models
 - 14.5 Single Forest, Multi-Domain, and Multi-Forest Designs
 - 14.6 Air-Gapped and Disconnected Environments
 - 14.7 Tactical, Lab, Test, Development, and Production Domains and Networks

- 14.8 Case Study: Poor Site Design Causing Authentication Failures
- Chapter 15. Domain Controllers (DCs) as Tier 0 Assets
 - 15.1 Domain Controller Security Model
 - 15.2 Physical and Virtual Domain Controllers (vDCs)
 - 15.3 RODCs and Subordinate Command Environments
 - 15.4 DC Placement in Federal Networks
 - 15.5 FSMO Roles and Operational Dependencies
 - 15.6 Global Catalog Serber (GCS) Considerations
 - 15.7 DC Backup, Recovery, and Continuous Monitoring (ConMon)
 - 15.8 Case Study: Over-Permissive Hypervisor Admins as Domain Compromise Attack Path
- Chapter 16. Active Directory Objects and Security Principals
 - 16.1 Users, Computers, Groups, Contacts, and Service Accounts
 - 16.2 Security Groups vs. Distribution Groups
 - 16.3 Global, Universal, and Domain Local Groups
 - 16.4 Managed Service Accounts (MSAs) vs. Group Managed Service Accounts (gMSAs)
 - 16.5 Privileged Groups vs. Built-In Groups
 - 16.6 AdminSDHolder and SDProp
 - 16.7 sIDHistory
 - 16.8 Stale, Orphaned, and Disabled Objects
 - 16.9 Case Study: Nested Group Membership Creating Hidden Privilege
- Chapter 17. Group Policy Architecture and Federal Security Baselines and Benchmarks
 - 17.1 Group Policy Object (GPO) Structure and Processing Order
 - 17.2 Local, Site, Domain, and Organizational Unit (OU) Policy Application
 - 17.3 Security Filtering and Windows Management Instrumentation (WMI) Filtering
 - 17.4 Inheritance, Enforcement, and Block Security Control Inheritance
 - 17.5 Central Store and Administrative Templates
 - 17.6 Secure Technical Implementation Guideline (STIG) Enforcement with Group Policy Objects (GPOs)
 - 17.7 Group Policy Object (GPO) Change Control Process
 - 17.8 Malicious and Accidental Group Policy Object (GPO) Risks
 - 17.9 Case Study: A Mis-Linked Group Policy Object (GPO) Disabling Audit Logging
- Chapter 18. Active Directory Sites, Replication, and Directory Consistency
 - 18.1 Multi-Master Replication
 - 18.2 KCC and ISTG
 - 18.3 Site Links vs. Replication Schedules
 - 18.4 Intra-Site vs. Inter-Site Replication
 - 18.5 SYSVOL and DFSR
 - 18.6 Replication Metadata
 - 18.7 Lingering Objects and Tombstones
 - 18.8 Replication as an Attack Surface
 - 18.9 Case Study: DCSync Rights Hidden in Delegated Permissions

PART IV – FEDERAL ICAM AND FICAM IMPLEMENTATION WITH ACTIVE DIRECTORY

- Chapter 19. Federal ICAM Architecture
 - 19.1 Identity Management
 - 19.2 Credential Management
 - 19.3 Access Management
 - 19.4 Federation Services and Management
 - 19.5 Governance and Lifecycle Management

19.6 Enterprise Roles and Authoritative Services

19.7 ICAM Shared Services

19.8 Case Study: HR-Driven Identity Lifecycle Failure

Chapter 20. PIV, PKI, CAC, Smart Cards, and Discovered Credentials

20.1 PIV and CAC Concepts

20.2 Certificate-Based Logon

20.3 Smart Card Authentication in Active Directory

20.4 UPN Mapping and AltSecurityIdentities

20.5 Derived PIV Credentials

20.6 Mobile and Remote Authentication

20.7 Revocation Checking and Certificate Revocation Lists (CRLs)

20.8 Case Study: Broken CRL Access Preventing Smart Card Logon

Chapter 21. NIST Digital Identity Assurance in Active Directory Environments

21.1 Identity Assurance Levels

21.2 Authentication Assurance Levels

21.3 Federation Assurance Levels

21.4 Authenticator Lifecycle Management

21.5 MFA and Phishing-Resistant Authentication

21.6 Password Policy vs. Authenticator Policy

21.7 Federation Assertions and Trust Decisions

21.8 Case Study: Mapping AAL Requirements to Active Directory and Entra ID Controls

Chapter 22. Active Directory Federation Services (AD FS) and Claims-Based Identity

22.1 Introduction to Active Directory Federations Services (AD FS) Architecture

22.2 Identity Providers (IdPs), Claims Providers, and Relying Parties

22.3 SAML, WS-Federation, OAuth, and OIDC

22.4 Token Signing and Token Decryption Certificates

22.5 Federation Metadata

22.6 Hybrid Identity and Cloud-Based Federation Services

22.7 Golden SAML Concepts

22.8 Case Study: Compromised Token-Signing Certificates From Rogue CA

Chapter 23. Active Directory Certificate Services (AD CS) in Federal Identity

23.1 Introduction to Enterprise Public Key Infrastructure (PKI) Architecture

23.2 Root and Subordinate Certificate Authorities (CAs)

23.3 Certificate Templates

23.4 Web Enrollment Agents

23.5 Autoenrollment

23.6 Smart Card Logon PIV Certificates

23.7 PKI Governance and Auditing Requirements for Mandatory Compliance

23.8 Active Directory Certificate Services (AD CS) Attack Surface

23.9 Case Study: Misconfigured Templates Allowing Domain Local Privilege Escalation

PART V – ETHICAL HACKING METHODOLOGY FOR FEDERAL AD SECURITY ASSESSMENTS

Chapter 24. Legal, Ethical, and Federal Assessment Boundaries

24.1 Authorization to Test

24.2 Rules of Engagement

24.3 Data Handling and Classification

24.4 CUI - Controlled Unclassified Information

24.5	Mission Impact Constraints
24.6	Safety Controls for Production Domains
24.7	Reporting Obligations
24.8	Case Study: When a Valid Exploit Is Not Authorized
Chapter 25.	Federal AD Assessment Methodology
25.1	Planning and Scope Definition
25.2	Stakeholder Interviews
25.3	Architecture Review
25.4	Data Collection
25.5	Tool Selection and Approval
25.6	Technical Validation
25.7	Risk Rating and Evidence Development
25.8	Executive and Technical Reporting
25.9	Remediation Roadmap
25.10	Case Study: Building an AD Assessment Package for Leadership
Chapter 26.	The Lab Design for Federal AD Offensive and Defensive Testing
26.2	Creating Multiple Domains and Forests
26.3	Simulating CAC/PIV and PKI
26.4	Adding AD FS and Hybrid Identity
26.5	Creating STIG and Non-STIG Baselines
26.6	Building Attack Paths Safely
26.7	Adding SIEM and EDR Telemetry
26.8	Case Study: Lab Validation Before Production Assessment
Chapter 27.	Threat Modeling Active Directory for Federal Enterprises
27.1	Mission Owner Perspective
27.2	Adversary Perspective
27.3	Defender Perspective
27.4	Insider Threat Perspective
27.5	Leadership and Upper Management Perspective
27.6	Stakeholder Perspective
27.7	End-User Perspective
27.8	Privileged Access Threats
27.9	Supply Chain and Federal Contractor Access
27.10	Advanced Persistent Threat (APT) Targeting of Federal Identity Systems
27.11	Case Study: Identity, Credential, and Access management Infrastructure as High-Value Cyber Terrain

PART VI – RECONNAISSANCE, ENUMERATION, AND ATTACK PATH MAPPING

Chapter 28.	Internal Domain Reconnaissance
28.1	Network Discovery
28.2	DNS (Domain Name Service) Enumeration
28.3	LDAP (Lightweight Directory Access Protocol) Enumeration
28.4	SMB (Server Message Block) Enumeration
28.5	RPC (Remote Procedure Call) Enumeration
28.6	Kerberos User Enumeration
28.7	Kerberos Computer Enumeration
28.8	Password Policy Discovery
28.9	Case Study: Low-Privilege Domain Recon Without Exploitation
Chapter 29.	PowerShell and Native Windows Enumeration

29.1	Active Directory PowerShell Module
29.2	PowerView Tool Overview
29.3	ADSI and LDAP Filters
29.4	Windows Management Instrumentation (WMI) and CIM
29.5	Event Log Queries
29.6	Constrained Language Mode Considerations
29.7	Defensive Logging of PowerShell Enumeration
29.8	Case Study: Detecting Suspicious Domain Enumeration
Chapter 30.	BloodHound and Graph-Based Attack Path Analysis
30.1	BloodHound Tooling Concepts
30.2	SharpHound Collection Tooling Methods
30.3	Privilege Graphs and Attack Pathways
30.4	Access Control List (ACL) and Session Mapping
30.5	Shortest Pathway to Domain Admin
30.6	Tier 0 Asset Mapping
30.7	Defensive BloodHound Usage
30.8	Case Study: Discovering Hidden Pathways Through Helpdesk Delegation
Chapter 31.	Service Account and Service Principal Name (SPN) Enumeration
31.1	Service Account Types
31.2	Service Principal Name (SPN) Discovery
31.3	Kerberoastable Accounts
31.4	Password Age and Encryption Type Review
31.5	Group Managed Service Account (gMSA) Discovery
31.6	Privileged Service Accounts
31.7	Defensive Service Account Inventory
31.8	Case Study: Legacy SQL Service Account with Domain Admin Rights
Chapter 32.	Trust Enumeration and Cross-Boundary Attack Paths
32.1	Domain Trusts
32.2	Forest Trusts
32.3	External Trusts
32.4	Shortcut Trusts
32.5	Selective Authentication
32.6	Security Identifier (SID) Filtering
32.7	Trust Key Abuse Concepts
32.8	Case Study: Contractor Forest Trust Misconfiguration
PART VII – OFFENSIVE ACTIVE DIRECTORY TRADECRAFT	
Chapter 33.	Password Attacks and Credential Guessing
33.1	Password Spraying Attack
33.2	Kerberos Pre-Authentication Enumeration
33.3	Brute-Force vs. Spraying Tradeoffs
33.4	Lockout Policy Considerations
33.5	Password Reuse
33.6	Federal Account Policy Constraints
33.7	Detection and Response
33.8	Case Study: Password Spray Against Legacy VPN (Virtual Private Network) Users
Chapter 34.	LLMNR, NBT-NS, WPAD, and NTLM Capture
34.1	Poisoning Attack Flow
34.2	Capturing NTLMv2 Material

34.3	Offline Cracking
34.4	Relay Opportunities
34.5	Responder and Inveigh Tooling Concepts
34.6	Defensive Controls
34.7	Detection Logic
34.8	Case Study: Helpdesk Information System as Credential Collection Point
Chapter 35.	Pass-the-Hash and NTLM Relay
35.1	New Technology Local Area Network Manager (NTLM) Hash Reuse
35.2	Local Admin Password Reuse
35.3	Pass-the-Hash (PtH) Attack Workflow
35.4	Server Message Block (SMB) Relay Attack
35.5	Lightweight Directory Access Protocol (LDAP) Relay Attack
35.6	Active Directory Certificate Services (AD CS) Relay Attack
35.7	PetitPotam and Coercion Concepts
35.8	EPA, Signing, and Channel Binding Best Practices
35.9	Case Study: Relay Attack to Certificate Web Enrollment Services
Chapter 36.	Kerberoasting and AS-REP Roasting
36.1	Kerberoasting Theory
36.2	Service Principal Names (SPNs) and Service Tickets
36.3	Ticket Encryption and Offline Cracking Requirements
36.4	AS-REP Roasting Attack Theory
36.5	Pre-Authentication Misconfiguration
36.6	Defensive Service Account Controls
36.7	Security Detection Engineering Explained
36.8	Case Study: Kerberoasting an Overprivileged Service Account
Chapter 37.	Passback Attacks: Pass-the-Ticket, Golden Tickets, and Silver Tickets
37.1	Kerberos Ticket Theft
37.2	Pass-the-Ticket (PtT) Attack Concepts
37.3	Pass-the-Hash (PtH) Attack Concept
37.4	Overpass-the-Hash (OtH) Attack Concepts
37.5	Pass-the-Key (PtK) Attack Concepts
37.6	KRBtgt Account Compromise
37.7	Golden Ticket Attack Concepts
37.8	Silver Ticket Attack Concepts
37.9	Diamond Ticket Attack Concepts
37.10	Sapphire Ticket Attack Concepts
37.11	Trust Tickets
37.12	Ticket Lifetime and Anomaly Detection
37.13	KRBtgt Password Rotation and Reset Strategy
37.14	Case Study: Long-Lived Ticket Persistence After Domain Compromise
Chapter 38.	Kerberos Authentication Protocol Delegation Abuse
38.1	Unconstrained Delegation
38.2	Constrained Delegation
38.3	Resource-Based Constrained Delegation (RBCD)
38.4	S4U2Self and S4U2Proxy
38.5	PrinterBug and Coercion Paths
38.6	Delegation Discovery
38.7	Defensive Delegation Review

38.8	Case Study: RBCD from Computer Account Takeover
Chapter 39.	ACL, Group, and Object Permission Abuse
39.1	GenericAll, GenericWrite, WriteDacl, WriteOwner Attributes
39.2	AddMember and Group Abuse
39.3	ForceChangePassword Attribute Abuse
39.4	Shadow Credentials
39.5	AdminSDHolder Abuse
39.6	sIDHistory Abuse
39.7	Defensive Access Control List (ACL) Review
39.8	Case Study: Helpdesk Delegation to Tier 0 Compromise
Chapter 40.	Group Policy Object (GPO) Abuse
40.1	Group Policy Object (GPO) Permissions
40.2	Malicious Windows Operating System Startup Scripts
40.3	Scheduled Tasks via Group Policy Object (GPO) Deployment
40.4	Local Administrators Through Restricted Groups
40.5	Group Policy Preferences (GPP) cpassword Legacy Risk
40.6	SYSVOL Exposure
40.7	Group Policy Object (GPO) Change Detection
40.8	Case Study: Malicious Group Policy Object (GPO) Used for Lateral Movement
Chapter 41.	Credential Dumping and Domain Credential Theft
41.1	LSASS Credentialed Material
41.2	Security Accounts Manager (SAM) and SYSTEM Hive Theft
41.3	NTDS.dit Exposure
41.4	DCSync
41.5	DPAPI and Browser Credential Risks
41.6	Local Administrator Password Solution (LAPS) and Windows LAPS Risks
41.7	Defensive Credential Storage Protection
41.8	Case Study: Backup Operator Path the NTDS.dit
Chapter 42.	Active Directory Certificate Services (AD CS) Abuse and Certificate-Based Escalation
42.1	Active Directory Certificate Services (AD CS) Attack Surface
42.2	ESC1 Through ESC16 Attack Concepts Defined
42.3	Misconfigured Certificate Templates
42.4	Certificate Web Enrollment Agent Abuse
42.5	NTLM Relay to Active Directory Certificate Services (AD CS) Infrastructure
42.6	Golden Certificate Compromise Concepts
42.7	Public Key Infrastructure (PKI) Logging and Monitoring
42.8	Case Study: Certificate Template Misconfiguration to Domain Admin
Chapter 43.	Active Directory Federation Services (AD FS) and Golden Security Assertion Markup Language (SAML) Attacks
43.1	Federation Trust Abuse
43.2	Token Signing Certificate Theft
43.3	SAML Assertion Forgery
43.4	Cloud Service Access Without Passwords
43.5	Active Directory Federation Services (AD FS) Service Account Risk
43.6	Defensive Certificate Protection
43.7	Federation Monitoring
43.8	Case Study: Golden SAML Against a Hybrid Federal Tenant
Chapter 44.	Domain Replication Abuse: DCSync and DCShadow Attacks

- 44.1 Directory Replication Services (DRS)
- 44.2 DS-Replication-Get-Changes Rights
- 44.3 DCSync Attack Concepts
- 44.4 DCShadow Attack Concepts
- 44.5 Rogue Replication Metadata
- 44.6 Detecting Abnormal Replication Workflows
- 44.7 Hardening Replication Permissions
- 44.8 Case Study: Replication Rights Hidden in Legacy Administrative Groups
- Chapter 45. Establishing and Maintaining Persistence in Active Directory
- 45.1 Golden Tickets
- 45.2 Silver Tickets
- 45.3 AdminSDHolder
- 45.4 Skeleton Key Concepts
- 45.5 Malicious Certificates Issuance
- 45.6 Rogue Group Policy Object (GPO) Containers
- 45.7 Directory Services Recovery Mode (DSRM) Persistence
- 45.8 sIDHistory
- 45.9 Abusing Domain Trusts for Persistence
- 45.10 Case Study: Persistence Surviving Password Resets and Server Reboots
- Chapter 46. Lateral Movement Across Federal Enterprise Networks
- 46.1 Server Message Block (SMB), Windows Management Instrumentation (WMI), Windows Remote Management (WinRM), Remote Desktop Protocol (RDP), and Sysinternals' PsExec-Style Movement
- 46.2 Remote Services Creation
- 46.3 Scheduled Tasks
- 46.4 PowerShell Remoting (PSR)
- 46.5 Admin Share Abuse
- 46.6 Cross-Enclave Constraints
- 46.7 Endpoint Detection and Response (EDR) and Security Information and Event Management (SIEM) Visibility
- 46.8 Case Study: Lateral Movement Through Shared Administrative Workstations
- Chapter 47. Advanced Persistent Threat (APT)-Directed Active Directory Attacks
- 47.1 Active Directory as High-Value Stakes and Terrain
- 47.2 Living-Off-The-Land (LOTL) in Windows Domains
- 47.3 Identity Provider (IdP) Targeting
- 47.4 Federation and Cloud Pivoting
- 47.5 Long-Dwell Time and Persistence
- 47.6 Supply Chain and Contractor Identity Abuse
- 47.7 Defensive Lessons From Public Intrusion Patterns
- 47.8 Case Study: Advanced Persistent Threat (APT) Targeting of Federal Identity Infrastructure

PART VIII – DEFENSIVE ACTIVE DIRECTORY SECURITY ENGINEERING

- Chapter 48. Federal Active Directory Hardening Strategy
- 48.1 Secure Baseline Design
- 48.2 STIG-Aligned Domain Controller Configuration
- 48.3 Tiered Administration
- 48.4 Privileged Access Workstations (PAWs) / Secured Administrative Workstations (SAWs)
- 48.5 Protected Users Group

- 48.6 Authentication Policy Silos
- 48.7 Legacy Protocol Reduction
- 48.8 Case Study: Building a Tier 0 Protection Program

Chapter 49. Privileged Access Management (PAM) for Federal Domains

- 49.1 Administrative Tiering
- 49.2 Just-In-Time (JIT) Administration
- 49.3 Just Enough Administration (JEA)
- 49.4 Break-Glass Accounts
- 49.5 Service Account Governance
- 49.6 Privileged Group Monitoring
- 49.7 PIM and PAM Integration
- 49.8 Case Study: Reducing Standing Domain Administrative Rights

Chapter 50. Hardening NTLM, Kerberos, and Authentication Protocols

- 50.1 NTLM Audit Mode
- 50.2 NTLM Blocking Strategy
- 50.3 Kerberos Encryption Type Hardening
- 50.4 RC4 and DES Reduction
- 50.5 LDAP Signing and Channel Binding Best Practices
- 50.6 SMB Signing
- 50.7 Credential Guard and Remote Credential Guard Security
- 50.8 Case Study: Phased NTLM Decommissioning

Chapter 51. Securing Domain Controllers

- 51.1 Physical and Virtual Domain Controller Security Guidance
- 51.2 Domain Controller Firewall Rules
- 51.3 Local Rights Assignments
- 51.4 Patch and Vulnerability Management
- 51.5 Backup Protection Procedures
- 51.6 NTP and Domain Controller Time Synchronization
- 51.7 Monitoring Domain Controller (DC) Processes
- 51.8 Case Study: Hypervisor Compromise as Domain Compromise

Chapter 52. Securing Group Policy Objects (GPOs)

- 52.1 Group Policy Object (GPO) Ownership and Delegation
- 52.2 Group Policy Object (GPO) Backup and Recovery Best Practices
- 52.3 Change Control Board (CCB) Approval Workflow
- 52.4 STIG'ing and Baselining Group Policy Objects (GPOs)
- 52.5 Malicious Group Policy Object (GPO) Detection
- 52.6 Group Policy Object (GPO) Conflict Analysis
- 52.7 Group Policy Object (GPO) Evidence for Federal Security Assessments
- 52.8 Case Study: Detecting Unauthorized Group Policy Object (GPO) Modifications

Chapter 53. Securing Active Directory Certificate Services (AD CS) and Public Key Infrastructure (PKI)

- 53.1 Public Key Infrastructure (PKI) Governance
- 53.2 Template Review
- 53.3 Certificate Authority (CA) Protection
- 53.4 Certificate Web Enrollment Restrictions
- 53.5 Certificate Manager Controls

53.6	Certificate Revocation Infrastructure
53.7	Certificate Abuse Detection
53.8	Case Study: Remediation ESC Findings
Chapter 54. Securing Active Directory Federation Services (AD FS) and Hybrid Identity	
54.1	Active Directory Federation Services (AD FS) Server Hardening
54.2	Token Signing Certificate Protection
54.3	Service Account Protection
54.4	Federation Trust Monitoring
54.5	Hybrid Identity Logging
54.6	Cloud Conditional Access Policies
54.7	Active Directory Federation Services (AD FS) Disaster Recovery
54.8	Case Study: Active Directory Federation Services (AD FS) Domain Breach and Compromise Readiness Plan
Chapter 55. Securing Name Resolution and Legacy Protocols	
55.1	Disabling LLMNR
55.2	Disabling NTB-NS
55.3	Securing WPAD
55.4	DNS Hardening
55.5	DHCP Controls
55.6	SMB Hardening
55.7	Legacy Protocol Inventory
55.8	Case Study: Removing Poisoning Risks via Group Policy Object (GPO) Security Control Deployment and Enforcement

PART IX – DETECTION SECURITY ENGINEERING, THREAT HUNTING, AND FORENSICS

Chapter 56. Active Directory Logging Architecture

56.1	Domain Controller Logs
56.2	Security Event Logs
56.3	Directory Service Logs
56.4	Kerberos Events
56.5	NTLM Events
56.6	PowerShell Logging
56.7	Sysmon and Endpoint Detection and Response (EDR) Telemetry
56.8	Case Study: Missing Logs During Domain Compromise

Chapter 57. Security Information and Event Management (SIEM) Use Cases for Active Directory

57.1	Microsoft Sentinel
57.2	Splunk
57.3	Elastic
57.4	QRadar
57.5	Event Normalization
57.6	Correlation Rules
57.7	Dashboard Design for Tracking Identified Domain Risks
57.8	Case Study: Building a Tier 0 Administrative Monitoring Dashboard

Chapter 58. Detecting Credential Attacks

58.1	Password Spray Attack Detection
58.2	Kerberoasting Attack Detection
58.3	AS-REP Roasting Attack Detection

- 58.4 Pass-the-Hash (PtH) Attack Detection
- 58.5 Pass-the-Ticket (PtT) Attack Detection
- 58.6 DCSync Attack Detection
- 58.7 Unauthorized LSASS Access Detection
- 58.8 Case Study: Detecting a Low-and-Slow Password Spraying Attack
- Chapter 59. Detecting Active Directory Certificate Services (AD CS), Active Directory Federation Services (AD FS), and Federation Abuse
- 59.1 Certificate Enrollment Mapping
- 59.2 Template Modification Detection
- 59.3 Suspicious Certificate Issuance
- 59.4 Active Directory Federation Services (AD FS) Token Signing Events
- 59.5 Federation Metadata Changes
- 59.6 Cloud Sign-In Correlation
- 59.7 Case Study: Suspicious Certificate Authentication Chain

Chapter 60. Threat Hunting Federal Active Directory FICAM Domains and Networks

- 60.1 Hunt Hypothesis Development
- 60.2 Hunting Privileged Group Changes
- 60.3 Hunting Delegation Abuse
- 60.4 Hunting Access Control List (ACL) Drift
- 60.5 Hunting Kerberos Anomalies
- 60.6 Hunting Replication Abuse
- 60.7 Hunting Trust Abuse
- 60.8 Case Study: Finding Dormant Persistence Before an Assessment

Chapter 61. Active Directory Digital Forensics and Incident Response (DFIR)

CHAPTER ABSTRACT

This chapter examines defensive forensic methodologies used to investigate Active Directory compromise, reconstruct attacker activity, identity persistence mechanisms, validate compromise scope, and collect evidentiary artifacts suitable for technical analysis, incident response, legal counsel and review, and federal reporting requirements. Readers will learn how to correlate Windows, Active Directory, Kerberos, NTLM, AD CS, AD FS, and cloud identity evidence to reconstruct and establish attacker timelines and support containment, eradication, and recovery and restoration procedures and operations.

- 61.1 Event Timeline Reconstruction and Attack Sequence Analysis
 - 61.1.1 Building a Chronological Timeline of Adversarial Activity
 - 61.1.2 Correlating Domain Controller Security Logs
 - 61.1.3 Correlating Authentication, Replication, and Administrative Events
 - 61.1.4 Identifying Initial Access, Privilege Escalation, Lateral Movement, and Persistent Phases
 - 61.1.5 Mapping Timeline Events to MITRE ATT&CK Techniques
 - 61.1.6 Establishing Scope, Duration, and Dwell Time
 - 61.1.7 Case Study: Reconstructing a Domain Admin Compromise
- 61.2 Authentication Evidence and Artifact Analysis for Identity Compromise Investigations
 - 61.2.1 Kerberos Authentication Evidence and Artifact Collection
 - 61.2.2 NTLM Authentication Evidence and Artifact Collection
 - 61.2.3 Logon Session Analysis
 - 61.2.4 Service Account Authentication Review
 - 61.2.5 Smart Card, PUV, and CAC Authentication Evidence and Artifacts

	61.2.6	Detecting Pass-the-Hash (PtH), Pass-the-Ticket (PtT), and Ticket Forgery Indicators of Compromise (IOCs)
61.3		Replication Metadata Analysis and Directory Services Forensics
	61.3.1	Understanding Federal Active Directory Replication Metadata
	61.3.2	Investigating Unauthorized Directory Modifications
	61.3.3	Detecting DCSync Activity Through Replication Artifacts
	61.3.4	Detecting DCShadow-Style Replication Manipulation and Attempts
	61.3.5	Reviewing Object Version Numbers and Attribute Changes
	61.6.6	Correlating Replication Events with Privileged Account Activity
61.4		Forensics Acquisition and Analysis of NTDS.dit Database Evidence
	61.4.1	Understanding NTDS.dit Structure and Contents
	61.4.2	Forensics Preservation of Active Directory Databases
	61.4.3	Identifying Unauthorized Credential Access Attempts
	61.4.4	Investigating Service Account and Privileged Account Exposures
	61.4.5	Reviewing Deleted, Stale, Tombstoned, and Recovered Active Directory Objects
	61.4.6	Evidentiary Considerations for Federal Investigations
61.5		Memory Forensics and LSASS Credential Artifact
	61.5.1	Understanding LSASS Memory Structures
	61.5.2	Credential Material Present in Memory
	61.5.3	Indicators of Credential Dumping Activity
	61.5.4	Detecting Suspicious Access to LSASS
	61.5.5	Memory Preservation and Chain-of-Custody Considerations
61.6		Defensive Group Policy and SYSVOL Forensics Review
	61.6.1	Investigating Unauthorized Group Policy Object (GPO) Modifications
	61.1.2	Forensics Analysis of SYSVOL Contents
	61.1.3	Reviewing Startup Scripts, Scheduled Tasks, and Logon Scripts
	61.1.4	Detecting Group Policy Persistence Mechanisms
	61.1.5	Identifying Malicious Configuration Changes
	61.1.6	Reconstructing Historical Group Policy Object (GPO) Activity
61.7		Hybrid Identity, Cloud, and Federation Artifact Correlation
	61.7.1	Correlating On-Premises and Cloud Authentication Events
	61.7.2	Investigating Microsoft Entra ID Sign-In Activity
	61.7.3	Reviewing AD FS Authentication and Federation Artifacts
	61.7.4	Investigating SAML, OAuth, and OpenID Connect Activity
	61.7.5	Detecting Golden SAML and Federation Trust Abuse Indicators
	61.7.6	Correlating Cloud Persistence with On-Premises Compromise
	61.7.7	Building a Unified Hybrid Identity Attack Timeline
61.8		Case Study: Reconstructing a Domain Administrator Compromise
	61.8.1	Initial Detection and Incident Notification
	61.8.2	Collection of Domain Controller, Endpoint, and Identity Artifacts
	61.8.3	Reconstruction of the Adversary Attack Timeline
	61.8.4	Identification of Privilege Escalation Pathways
	61.8.5	Discovery of Persistence Mechanisms
	61.8.6	Correlation of On-Premises and Cloud Evidence
	61.8.7	Determining Scope, Impact, and Mission Risk
	61.8.8	Lessons Learned, Containment Actions, and Recovery
Recommendations		

PART X – INCIDENT RESPONSE (IR), RECOVERY, AND COMMAND MISSION RESILIENCE

Chapter 62. Defensive Incident Response (IR) for Suspected Active Directory Compromise

- 62.1 Defensive Triage and Enterprise Scope Validation
 - 62.1.1 Confirming Initial Indicators of Compromise (IOC)
 - 62.1.2 Identifying Impacted Forests, Domains, Domain Controllers (DCs), PAWs/SAWs, and Privileged Accounts
 - 62.1.3 Separating Suspected Compromise from Confirmed Compromise
- 62.2 Containment Decision-Making for Tier 0 Assets
 - 62.2.1 When to Isolate Domain Controllers (DCs)
 - 62.2.2 When to Disable Accounts, Block Protocols, or Server Trust Paths
 - 62.2.3 Balancing Containment Against Mission Availability
- 62.3 Credential Reset Strategy for Enterprise Identity Recovery
 - 62.3.1 Prioritizing Domain Admins, Enterprise Admins, Service Accounts, and Break-Glass Accounts
 - 62.3.2 Sequencing Resets to Avoid Attacker Reuse
 - 62.3.3 Validating Credential Hygiene After Reset Operations
- 62.4 KRBTGT Password Rotation Strategy After Kerberos Compromise
 - 62.4.1 When KRBTGT Rotation Is Required
 - 62.4.2 Single Reset vs. Dual Reset Strategy
 - 62.4.3 Ticket Lifetimes, Replication Timing, and Operational Impact
- 62.5 Certificate Revocation Strategy for Active Directory Certificate Services (AD CS) and Smart Card Environments
 - 62.5.1 Revoking Compromised Certificates
 - 62.5.2 Validating Certificate Revocation Lists (CRLs) and OCSP Availability
 - 62.5.3 Reviewing Certificate Templates, Web Enrollment Agents, and Certificate Authority (CA) Logs
 - 62.5.4 Protecting PIV/CAC Authentication Integrity
- 62.6 Trust and Federation Response for Active Directory Federation Services (AD FS), Entra ID, and Cross-Forest Relationships
 - 62.6.1 Reviewing Forest Trusts, External Trusts, and Selective Authentication
 - 62.6.2 Rotating Active Directory Federation Services (AD FS) Token-Signing and Token-Decryption Certificates
 - 62.6.3 Validating SAML, WS-Fed, OAuth, and OIDC Trust Relationships
 - 62.6.4 Checking for Cloud Persistence After On-Premises Compromise
- 62.7 Communication with Mission Owners, Authorizing Officials (AOs), CSSP and ALCON
 - 62.7.1 Translating Technical Compromise Into Mission Impact
 - 62.7.2 Coordinating with ISSM, ISSO, SCA, AO, CSSP, and System Owners
 - 62.7.3 Reporting Status, Containment Actions, and Residual Risk
 - 62.7.4 Preserving Chain-of-Custody and Incident Documentation
- 62.8 Case Study: Responding to Suspected Domain Controller Compromise
 - 62.8.1 Initial Alert: Abnormal Replication or Privileged Logon Activity
 - 62.8.2 Investigation Path: DC Logs, Kerberos Events, Replication Metadata, and Admin Account Usage
 - 62.8.3 Containment: Account Disablement, Trust Review, KRBTGT Planning, Evidence and Artifact Preservation
 - 62.8.4 Recovery: Credential Reset, DC Validation, POA&M Updating, and

After-Action Reporting

Chapter 63. Active Directory (AD) Forest Recovery and Disaster Recovery

- 28.1 Domain and Forest Post-Compromise Recovery Planning
- 28.2 System State Backups
- 28.3 Authoritative and Non-Authoritative Restores
- 28.4 Bare Metal Recovery Procedures
- 28.5 Rebuilding Domain Controllers (DCs) From Scratch
- 28.6 Recovering SYSVOL
- 28.7 Verifying and Validating Trust and Replication Health
- 28.8 Case Study: Ransomware Impacting Domain Controllers

Chapter 64. Defensive Resilience Engineering for Federal Active Directory

- 64.1 Redundancy and Availability
- 64.2 Backup Isolation
- 64.3 Break-Glass Operations
- 64.5 Disaster Recovery Exercises
- 64.6 Tabletop Exercises
- 64.7 Mission Continuity Planning
- 64.8 Case Study: Active Directory (AD) Outage During Command Mission Operations

PART XI – REPORTING, REMEDIATION, AND FEDERAL ASSESSMENT DELIVERABLES

Chapter 65. Writing Federal AD Findings

- 65.1 Executive Summary Language
- 65.2 Technical Finding Structure
- 65.3 Evidence and Artifacts Screenshotting
- 65.4 Severity Ratings
- 65.5 CAT Mapping
- 65.6 RMF Control Mapping
- 65.7 Mission Impact Statements
- 65.8 Case Study: Turning Kerberoasting Into an Actionable and Meaningful Finding

Chapter 66. Remediation Planning and Validation

- 66.1 Corrective Action Plans
- 66.2 POA&M Development
- 66.3 Prioritization by Command Mission Risk Severity
- 66.4 Quick Wins vs. Structural Remediation
- 66.5 Verification and Validation Testing
- 66.6 Residual Risk
- 66.7 Leadership Reporting, Transparency, and Clear Communication
- 66.8 Case Study: Closing a CAT I Finding Without Breaking Operations

Chapter 67. Assessment Tooling and Reference Toolkit

- 67.1 Native Microsoft Tools
- 67.2 PowerShell Tools
- 67.3 BloodHound and SharpHound
- 67.4 Impacket Tool Suite
- 67.5 Rubeus
- 67.6 Mimikatz Concepts and Defensive Use
- 67.7 PingCastle
- 67.8 Purple Knight
- 67.9 ADRecon
- 67.10 STIG Viewer, SCC, ACAS, and SCAP

67.11 Tool Approval in Federal Environments (Approved Software Security List – ASSL)

PART XII – FUTURE FEDERAL IDENTITY, CREDENTIAL AND ACCESS MANAGEMENT AND ACTIVE DIRECTORY (AD) MODERNIZATION

Chapter 68. Hybrid Identity and Microsoft Entra Integration

- 68.1 Entra ID and Active Directory Federation Services (AD FS) Relationship
- 68.2 Entra Connect and Cloud Sync
- 68.3 Password Hash Sync
- 68.4 Pass-Through Authentication
- 68.5 Federation vs. Managed Authentication
- 68.6 Conditional Access
- 68.7 Hybrid Attack Paths
- 68.8 Case Study: On-Prem Active Directory (AD) Compromise to Cloud Privilege

Chapter 69. Zero Trust Network Architecture (ZTNA) and Federal Identity Modernization

- 69.1 Zero Trust Network Architecture (ZTNA) Identity Principles
- 69.2 Continuous Verification and Validation
- 69.3 Device Trust and Secure Mobile Device Management (MDM)
- 69.4 Privileged Access Segmentation Strategies
- 69.5 Phishing-Resistant Multi-Factor Authentication (MFA)
- 69.6 Identity Governance
- 69.7 Continuous Diagnostics and Migration
- 69.8 Case Study: Applying Zero Trust to a Legacy Active Directory (AD) Forest

Chapter 70. Passwordless, FIDO2, and Future Authentication

- 70.1 Passwordless Authentication Concepts
- 70.2 FIDO2 Security Keys
- 70.3 Windows Hello for Business
- 70.4 Smart Card Modernization
- 70.5 Passkeys
- 70.6 Derived Credentials
- 70.7 Federal Deployment Challenges
- 70.8 Case Study: Migrating from Password-Centric Active Directory (AD) to Phishing-Resistant Conditional Access Authentication

Appendices

- Appendix A. Federal Active Directory Assessment Checklist
- Appendix B. FICAM and ICAM Control Mapping Checklist
- Appendix C. RMF Control Mapping for Active Directory
- Appendix D. STIG and SRG Mapping for Domain Controllers
- Appendix E. CAT I, CAT II, and CAT III Finding Examples
- Appendix F. POA&M Template
- Appendix G. CCRI / CORA Readiness Checklist for Federal Active Directory
- Appendix H. eMASS Evidence and Artifact Template for Active Directory

Security Controls Implementation

- Appendix I. Active Directory Attack Technique Matrix
- Appendix J. MITRE ATT&CK Framework Mapping for Active Directory, Active Directory Certificate Services (AD CS), Active Directory Federation Services (AD FS), and Hybrid Identity
- Appendix K. Important Security Log Event IDs for Kerberos

- Appendix L. NTLM Event ID Reference
- Appendix M. Active Directory Certificate Services (AD CS) Event ID Reference
- Appendix N. Active Directory Federation Services (AD FS) Event ID Reference
- Appendix O. PowerShell Enumeration Reference
- Appendix P. LDAP Query Reference
- Appendix Q. BloodHound Defensive Query Reference
- Appendix R. Active Directory Hardening Checklist
- Appendix S. Active Directory Certificate Services (AD CS) Hardening

Checklist

- Appendix T. Active Directory Federation Services (AD FS) Hardening Checklist
- Appendix U. Incident Response (IR) Playbooks
- Appendix V. Forest Recovery Checklist
- Appendix W. Sample Rules of Engagement for Federal Active Directory (AD)

Assessments

- Appendix X. Sample Executive Reporting Template
- Appendix Y. Sample Technical Findings Report Template
- Appendix Z. Sample POA&M Language for Active Directory (AD) Findings
- Appendix AA: AS-REP Event Log Reference
- Appendix BB: LDAP Query Templates
- Appendix CC: Hashcat and John Configuration Files
- Appendix DD: AS-REP Roast Hash Format Specifications Cheatsheet
- Appendix EE: Mimikatz and Rubeus Commands Cheatsheet
- Appendix FF: PowerShell Scripts for Security Auditing
- Appendix HH:

Additional Chapters That Need a Home

Chapter X. Cybersecurity Overview

- Introduction to Cybersecurity
- o Overview of Cybersecurity Domains
- o Definition of Cybersecurity
- o Cybersecurity vs. Information Security vs. Network Security
- o Scope and Areas of Focus
- Importance of Information Security (InfoSec)
- o Information Security Refresher
- o Protecting Sensitive Data
- o Maintaining Business CIA
- o Compliance Adherence to Regulations and Security Mandates
- Current Trends in Cybersecurity
- o The AI/ML Boom
- o Rise of Remote Work Security Challenges
- o Increasing Use of Cloud-Based Services
- o Focus on Zero Trust Network Architecture (ZTNA)
- Cybersecurity Frameworks
- o Commercial and Public Sector
- o NIST Cybersecurity Framework (NIST CSF)
- o ISO/IEC 27001X
- o CIS CSC – Center for Internet Security – Critical Security Controls
- o RMF – Risk Management Framework
- o GDPR – General Data Protection Regulation

- ❑ HIPAA – Health Insurance Protection Accountability Act
- ❑ PCI DSS – Payment Card Industry Data Security Standard
- o Federally Regulated Frameworks
 - ❑ CMMC
 - ❑ FISMA
 - ❑ FedRAMP
 - ❑ RMF
- o Legacy Federal Frameworks
 - ❑ NISPOM
 - ❑ DIACAP
 - ❑ DITSCAP
- Cybersecurity Threat Landscape
- o Evolving Cyber Threats
 - ❑ Emerging Malware Types
 - Fileless Malware
 - Ransomware-as-a-Service (RaaS)
 - ❑ Targeted Attacks
 - Spearphishing
 - Whaling
 - BEC – Business Email Compromise
 - Supply Chain Attacks
- o Mitigation Strategies
 - ❑ Risk Assessment
- o Threat Actors
 - ❑ Attacker Motivations
 - Financial Gain
 - Ideological Beliefs
 - Political Motives
 - ❑ Types of Attackers
 - Cybercriminal Organizations
- o Nation-State
 - ❑ Advanced Persistent Threat (APT)
 - ❑ Intelligence Agencies
 - ❑ Governmental Agencies
- o State-Sponsored
 - ❑ Advanced Persistent Threat (APT)
- o Hacktivists
 - Lone Wolves
 - Suicide Hackers
 - Leets
 - Script Kiddiez / Skiddz / n00bs
- o Vulnerabilities and Increasing Risks
 - ❑ Attack Surface Expansion
 - BYOD Vulnerabilities
 - IoT Device Vulnerabilities
 - Remote Work Challenges
 - ❑ Common Vulnerabilities
 - Misconfigured Systems
 - Unpatched Software

Chapter X. Golden Ticket Attacks

PART I – Foundations

- Chapter 1: Introduction to Kerberos Authentication Protocol and Active Directory
 - o The Kerberos Authentication Protocol
 - o AS and TGS Exchanges
 - o Key Distribution Center (KDC) Role
 - o Ticket Granting Tickets (TGTs) vs. Service Tickets (STs)
 - o The Privileged Attribute Certificate (PAC)
 - o The Significance of the KRBTGT Domain Account
- Chapter 2: The Anatomy of a Golden Ticket Attack
 - o Defining Golden Ticket
 - o Post-Exploitation Nature of Attack - Why It Happens After Infiltration
 - o Key Components Needed to Craft Golden Tickets
 - o Domain SID
 - o User UID
 - o KRBTGT Hash
 - o The Goldmine – Impact of Total Domain Compromise
- Chapter 3: Offensive Prerequisites and Setup
 - o Initial Access Strategies
 - o Phishing
 - o Vulnerability Exploitation
 - o Establishing Domain Admin (DA) Privileges
 - o Extracting the KRBTGT Hash
 - o LSASS Memory Dumps
 - o Advanced Extraction
 - o DCSync and Replication Abuse

PART II – The Offensive Perspective (Attack Techniques)

- Chapter 4: Creating the Golden Ticket (The Forgery Process)
 - o Using Mimikatz for Ticket Generation
 - o Using Rubeus and Other Open-Source Hacking Tools
 - o Forging PAC Data for Elevated Privileges
 - o Setting Long-Term Persistence (10+ Year Lifetime)
- Chapter 5: Advanced Exploitation and Evasion
 - o Injecting Tickets Into Memory
 - o Bypassing Traditional EDR and AV Systems
 - o Golden Ticket vs. Silver Ticket – Key Differences
 - o Lateral Movement Using Forged TGTs
- Chapter 6: Covering Tracks
 - o Tampering with SECURITY and SYSTEM Event Logs
 - o Timestamp Manipulation of Issued Tickets
 - o Clearing Local Cache Memory

PART III – The Defensive Perspective (Mitigation and Detection)

- Chapter 7: Preventive Measures (Reducing the Attack Surface)
 - o Enforcing Tiered Administration
 - o Tier 0
 - o Tier 1
 - o Tier 2
- Chapter 8: Restricting Domain Controller (DC) Access
 - o Implementing Local Administrator Password Solution (LAPS)
 - o Hardening of LSASS

- o Credential Guard and Supporting Protection Mechanisms
- Chapter 9: Detection and Behavioral Analysis
- o Monitoring for Abnormal KRBTGT Access
- o Identifying Unusual TGT Lifespans
- o Analyzing Kerberos Event IDs
- 🔍 4624
- 🔍 4768
- 🔍 4769
- Chapter 10: Using SIEM and XDR to Detect Inconsistent PAC Data
- Chapter 11: Incident Response (IR) and Remediation
- o Identifying a Compromise – The Smoking Gun
- o The Double KRBTGT Reset and Password Rotation Process
- o Post-Reset Considerations
- 🔍 Disrupting Kerberos Network Traffic
- o Forensic Analysis of Forged Tickets
- PART IV – Future Landscape
- Chapter 12: The Evolution of Kerberos Threats
- o Cloud Hybrid Scenarios
- 🔍 Azure AD
- 🔍 Entra ID
- Future of Identity, Credential, and Access Management (ICAM)-Based Attacks

Chapter X. Unauthorized Active Directory (AD) Initial Access: GPO Abuse, Lateral Movement, and Privilege Escalation

1. Introduction to the Active Directory Attack Surface
 - 1.1 GPO Abuse, Lateral Movement, and Initial Privesc Ecosystem
 - 1.2 MITRE ATT&CK Framework Coverage
 - 1.2.1 T1484
 - 1.2.2 TA0008
 - 1.2.3 TA0004
 - 1.3 Attack Chain Interdependencies
 - 1.4 Scope and Rules of Engagement
 - 1.4.1 Domain vs. Local vs. Cloud Contexts
 - 1.5 The Administrative Trust Model and Why It Constantly Fails
 - 1.6 How Misconfigurations Accumulate
 - 1.7 Threat Actor Profiles
 - 1.7.1 Who Uses These Techniques and Why
 - 1.8 Real-World Intrusion Campaign: GPO-Based Lateral Movement
 - 1.9 Chapter Roadmap – How the Attack Chain Maps to This Handbook
2. Windows Security Architecture Foundations
 - 2.1 The Windows Security Reference Monitor and Access Token Model
 - 2.2 Mandatory Integrity Control
 - 2.2.1 Integrity Levels and User Access Control (UAC)
 - 2.3 Security Identifiers (SIDs) and Relative Identifiers (RIDs)
 - 2.4 Access Control Lists (ACLs)
 - 2.4.1 Discretionary Access Control List (DACL)
 - 2.4.2 System Access Control List (SACL)
 - 2.4.3 Access Control Entry (ACE) Evaluation Order

- 2.5 Windows Authentication Protocols
 - 2.5.1 NTLM vs. Kerberos
- 2.6 Local Security Authority (LSA) and the Credential Storage Model
- 2.7 Windows Token Impersonation and Delegation
- 2.8 Protecting Operating Systems-Specific Processes and Credential Guard
- 2.9 How Windows Handles Privilege Separation at the Kernel Level
- 2.10 Security Architecture Gaps
 - 2.10.1 GPO Abuse and Lateral Movement Exploitation
- 3. Active Directory Architecture for Attackers
 - 3.1 The Active Directory (AD) Information Model
 - 3.1.1 Forests
 - 3.1.2 Domains
 - 3.1.3 Trees
 - 3.1.4 Trust Boundaries
 - 3.2 The Lightweight Directory Access Protocol (LDAP) Directory Service
 - 3.2.1 How Active Directory Stores and Exposes Object Data
 - 3.3 Domain Controller (DC) Components
 - 3.3.1 Roles
 - 3.3.2 Replication
 - 3.3.3 Flexible Single Master Operator (FSMO) Model
 - 3.3.3.1 Forest-Wide Roles
 - 3.3.3.3.1 Schema Master
 - 3.3.3.3.2 Domain Naming Master
 - 3.3.3.2 Domain-Wide Roles
 - 3.3.3.2.1 Relative ID (RID) Master
 - 3.3.3.3.2 Primary Domain Controller Emulator (PDCe)
 - 3.3.3.3.3 Infrastructure Master
 - 3.4 The Global Catalog Service (GCS) and Its Role In Enumeration
 - 3.5 Active Directory Object Classes and Attributes Relevant to Offensive Operations
 - 3.5.1 Computer and User Account Structural Classes
 - 3.5.2 Privileged Group Membership Mapping
 - 3.5.3 User Account Control (UAC) Attribute Flags
 - 3.5.3.1 Bitwise Masking and Flag Decoding
 - 3.5.3.2 Delegation Flag Abuse: TRUSTED_FOR_DELEGATION - Unconstrained Delegation
 - 3.5.3.3 Pre-Authentication Bypass: DON'T_REQ_PREAUTH - AS-REP Roasting Flag
 - 3.5.3.4 Sensitive Accounts and Smart Card Flags
 - 3.5.3.4.1 DONT_EXPIRE_PASSWORD
 - 3.5.3.4.2 SMARTCARD_REQUIRED
 - 3.5.3.5 Scripted Enumeration and Parsing
 - 3.5.4 Service Principal Name (SPN) Enumeration
 - 3.5.5 Security Descriptor and Access Control List (ACL) Modification
 - 3.5.6 Active Directory Kerberos Delegation Properties
 - 3.5.6.1 Hunting for Delegation Misconfigurations
 - 3.5.6.1.1 msDS-AllowedToDelegateTo (Constrained Delegation)
 - 3.5.6.1.2 msDS-AllowedToActOnBehalfOfOtherIdentity (Resource-Based Constrained Delegation (RBCD))
 - 3.5.6.1.3 Highly Exploitable UAC Bitmask Combinations
 - 3.5.6.1.3.1 Unconstrained Delegation Harvesting - Hunting for 0x80000
 - 3.5.6.1.3.2 AS-REP Roasting Targets - Hunting for 0x400000

- 3.5.6.1.3.3 Stale Account Persistence – Hunting for 0x10000
- 3.5.6.1.3.4 Inter-Domain Trust Abuse – Hunting for 0x800
- 3.5.6.1.3.5 Password Not Required Risk – Hunting for 0x20
- 3.6 Distinguished Names (DNs), Canonical Names (CNAME), and Object Paths
- 3.7 Active Directory Replication
 - 3.7.1 Unique Sequence Numbers (USNs)
 - 3.7.1.1 Local USN Incrementing
 - 3.7.1.2 High Watermark Vector
 - 3.7.1.3 Up-To-Dateness Vector (UTDV)
 - 3.7.2 Originating Updates
 - 3.7.2.1 Attribute-Level Stamp
 - 3.7.2.2 Replicated Updates vs. Originating Updates
 - 3.7.3.3 Urgent Replication
 - 3.7.3 Replication Conflicts
 - 3.7.3.1 Multi-Master Replication Conflicts
 - 3.7.3.1.1 Simultaneous Attribute Modifications
 - 3.7.3.1.2 Intra-Site vs. Inter-Site Latency Windows
 - 3.7.3.1.3 Object Creation Collisions
 - 3.7.3.2 Last-Writer-Wins (LWW) Evaluation
 - 3.7.3.2.1 Version Number Comparison
 - 3.7.3.2.2 Timestamp Analysis
 - 3.7.3.2.3 DSA GUID Tie-Breaking
 - 3.7.3.3 Conflict Objects (CNF)
 - 3.7.3.3.1 CNF Naming Syntax
 - 3.7.3.3.2 Container Object Resolution
 - 3.7.3.3.3 Manual Cleanup Procedures
- 3.8 Trust Relationships
 - 3.8.1 Built-In (Implicit) Trusts
 - 3.8.1.1 Parent-Child (Two-Way / Transitive Trust)
 - 3.8.1.2 Tree-Root (Two-Way / Transitive Trust)
 - 3.8.2 Explicit Trusts
 - 3.8.2.1 External Trust (Non-Transitive Trust)
 - 3.8.2.2 Forest Trust (Transitive Trust)
 - 3.8.2.3 Shortcut Trust (One-Way or Two-Way / Transitive Trust)
 - 3.8.3 Trust Directions and Transitivity
 - 3.8.3.1 One-Way, Unidirectional Trust
 - 3.8.3.2 Two-Way, Bidirectional Trust
 - 3.8.3.3 Transitive Trust
 - 3.8.3.4 Non-Transitive Trust
 - 3.8.4 Shortcut Trusts
- 3.9 The AdminSDHolder Mechanism and Protected Domain Accounts
- 3.10 Read-Only Domain Controllers (RODCs)
 - 3.10.1 Architecture and Attack Surface

Chapter X. Foundations of Federal Vulnerability and Compliance Assessment

- 1. Foundations of Federal Vulnerability and Compliance Assessment
 - 1.1 Introduction to the Security Content Automation Protocol (SCAP) Framework
 - 1.2 NIST SP 800-126, Standardization and the Evolution of Open Security Metrics
 - 1.3 The Role of SCAP in Federal Risk Management Framework (RMF) Authorization
 - 1.4 Extensible Configuration Checklist Description Format (XCCDF) Structure

- 1.5 Open Vulnerability and Assessment Language (OVAL) Schema and Logic
- 1.6 Common Vulnerability Scoring System (CVSS) Metric Mapping
- 1.7 Common Platform Enumeration (CPE) Asset Nomenclature
- 1.8 Common Vulnerabilities and Exposures (CVE) Dictionary Integration
- 1.9 Standardizing Human-Readable Policies Into Machine-Readable Formats
- 1.10 Automating DISA STIG and CIS Benchmark Distribution Across Agencies
- 1.11 Achieving Repeatable Configuration Baselines Across Non-Homogenous Networks
- 2. SCC (SCAP Compliance Checker)
- 2.1 Introduction to the NIWC SCAP Compliance Checker (SCC) Utility
- 2.2 Architecture of Local Agentless Scanning Utilities
- 2.3 Sourcing, Validating, and Importing Official DISA SCAP Content Packages
- 2.4 Configuring the SCC Graphical User Interface (GUI) for Manual Audits
- 2.5 Command-Line Interface (CLI) Execution and Automated Scripting Parameters
- 2.6 Programmatic Assessments
- 2.7 Local File Permissions and ACL Auditing
- 2.8 Evaluating Local Group Policy Objects (GPOs) Enforcement States
- 2.9 Analyzing SCC Output Formats
- 2.9.1 XML
- 2.9.2 HTML
- 2.9.3 Text Summaries
- 2.10 Generating Compliant Audit Evidence for FISMA and RMF ATO (Authority/Authorization to Operate) Packages
- 2.11 Troubleshooting Common SCC False Positives and Scanning Failures
- 3. ACAS (Assured Compliance Assessment Solution)
- 3.1 Introduction to the DoD Assured Compliance Assessment Solution (ACAS) Platform
- 3.2 Understanding the Mandated Tenable Technology Stack Ecosystem
- 3.3 Role of Tenable.sc (Security Center) in Centralized Vulnerability Management
- 3.4 Deploying and Configuring Distributed Nessus Active Network Scanners
- 3.5 Implementing Nessus Network Monitor (NMM) Passive Listening Sensors
- 3.6 Managing Continuous Plugin Feed Updates and Threat Intel Ingestion
- 3.7 Configuring Credentialed Network Scans for Deep Host Inspections
- 3.8 Network Asset Discovery and Automated Dynamic Asset Groupings
- 3.9 Building Centralized Macro-Level Enterprise Risk Dashboards in Nessus
- 3.10 Formatting Vulnerability Data for Command Cyber Readiness Inspections (CCRI)
- 3.11 Remediation Tracking Accountability and Vulnerability Lifecycle Management
- 3.11.1 eMASS
- 3.11.2 Vulnerability Management System (VMS)
- 3.11.3 Plan of Action and Milestone (POA&M)

Chapter X. Tactical Active Directory Exploitation and Hardening in Federal Active Directory Environments

- 1.1 Federal Active Directory Architecture and the Defense-in-Depth Reality
- 1.1.2 The Federal Blueprint
- 1.1.2.1 Navigating Multi-Forest Agencies
- 1.1.2.2 Cross-Agency Trust Relationships
- 1.1.2.3 IC/DoD Classifications
- 1.1.3 SIPR vs. NIPR AD Mechanics
- 1.1.3.1 Air-Gapped Domain Controller Syncing

- 1.1.3.2 Strict Isolation Boundaries
- 1.1.3.3 Identity Federation
- 1.1.4 The Federal Attacker Mindset
 - 1.1.4.1 Operating Under Assume Breach in Environments with Aggressive Endpoint Detection and Continuous Monitoring
- 2. Offensive Enumeration: Bypassing and Weaponizing Federal Vulnerability Scanners
 - 2.1 ACAS (Assured Compliance Assessment Solution) Blindspots: Identifying Assets and Latent AD Objects Missed by Nessus Aggressive Scans
 - 2.2 Weaponizing Secure Content Automation Protocol (SCAP) Compliance Data: Extracting Misconfigurations Directly from Reachable SCAP Compliance Mapping Files and XML Reports
 - 2.3 Low-and-Slow Active Directory Discovery
 - 2.3.1 Stealthy LDAP Query Construction
 - 2.3.2 BloodHound and SharpHound – Evading Host-Based Security Suite (HBSS)/Enterprise Security Suite (ESS) and ACAS
- 3. Weaponizing and Hardening Exploitable User Access Control (UAC) Bitmask Combinations
 - 3.1 Defensive Security Baseline Enforcement
 - 3.1.1 Auditing UAC Flags with PowerShell
 - 3.1.2 Automating DISA STIG for PASSWD_NOTREQD and DONT_EXPIRE_PASSWORD

Remediation
Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. Introduction to Ethical Hacking

Chapter Objectives

Key Terms

Introduction to Ethical Hacking

Overview of Ethics

Importance of Security

Threats and Vulnerabilities

Cyber Attacks

Security Breaches

Exposure

Components of Information Security

Elements of Information Security

Authentication, Authorization, Accountability (AAA)

Reusability

The Security, Functionality and Ease of Use Triangle

The CIA Triad

The Parkerian Hexad

Defense-in-Depth/Defense-in-Breadth

Information Security Policies and Procedures

Core Information Security Principles

Security Objectives

Risks, Assets, Threats, and Vulnerabilities

Data Backup and Recovery

Exploit Definition

Risk Evaluation

Overview of Ethical Hacking

Ethical Hackers vs. Unethical Hackers

Importance and Benefits of Ethical Hacking

History and Evolution of Hacker Classes and Hacking

Hackers and Crackers

Hacker Traits and Profiles

Types of Hackers

Attack and Threat Modeling

Cyber Kill Chain (CKC) Methodology

MITRE ATT&CK Framework

MITRE D3F3ND Framework

Phases of Common Cyber Attacks

Methodology of Ethical Hacking

Attack Modeling

Phase 1 - Reconnaissance/Information Gathering/Footprinting

Phase 2 - Network Scanning

Phase 3 - Enumeration

Phase 4 - Gaining Initial Access

Phase 5 - Maintaining Access (Foothold) and Persistence

Phase 6 - Privilege Escalation, Lateral Movement, and Pivoting
Phase 7 - Exploitation and Post-Exploitation
Phase 8 - Covering Tracks/Clean Up and Exit Strategy
Types of Ethical Hacking Security Testing
Test Planning and Legal Considerations
The Scope and the Questionnaire
Success Criteria
Defining Non-Disclosure Agreement (NDA)
Obtaining Authorization and Consent (Get Out of Jail Free Card)
Rules of Engagement (ROE)
Ethical Hacking Deliverables (Summary, Documentation)
Types of Penetration Tests
Black Box Testing (No-Knowledge)
Gray Box Testing (Partial-Knowledge)
White Box Testing (Full-Knowledge)
Security Assessments and Audit Types
Types of Hacker Attacks
Operating System (OS) Attacks
Application-Level Attacks
Shrink-Wrap Code Attacks
Misconfiguration Attacks
Hacktivism
Categorization of Hacker Types and Classes
Ethical Hackers
What Do Ethical Hackers Do?
What Can You Do Legally?
Laws of the Land
Is Port Scanning Legal?
Can Hacking Be Ethical?
KSAs (Knowledge, Skills, Abilities) of an Ethical Hacker
Key Skills for Ethical Hackers
Relevant Laws and Guidelines
What is Vulnerability Research?
Why Hackers Need Vulnerability Research, Analysis, and Assessment
Vulnerability and Exploit Key Websites of Interest
Conducting Ethical Hacking
How Do They Go About It?
Approaches to Ethical Hacking
Ethical Hacking Testing
Ethical Hacking Deliverables
Computer Crimes and Implications
Ethics and Legalities
U.S. Federal Law Overview
Compliance and Regulatory Bodies
Payment Card Industry Data Security Standard (PCI DSS)
Health Insurance Portability and Accountability Act (HIPAA)
Sarbanes-Oxley (SOX)
General Data Protection Regulation (GDPR)
Legal Perspective (U.S. Federal Law)
Section 1029 and Penalties

Section 1030 and Penalties

Chapter Summary

Recommended Reading and Resources.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. ACAS, SCC, SCAP

1.

Chapter X. Malicious Artificial Intelligence (AI) and Machine Learning (ML) for Active Directory Attacks

1.

Chapter X. The Case for a Federal Active Directory (AD) FICAM Handbook

1.

Chapter X. The Case for a Federal Active Directory (AD) FICAM Handbook

1.

Chapter X. The Case for a Federal Active Directory (AD) FICAM Handbook

1.

Chapter X. The Case for a Federal Active Directory (AD) FICAM Handbook

1.

Chapter X. System Hacking

Chapter Objectives

Key Terms

Introduction to System Hacking

Cracking Passwords

Password Types

Password-Related Cyber Attacks

Password Cracking - Key Websites of Interest

<https://www.defaultpassword.com/>

<https://www.cirt.net/cgi-bin.passwd.pl>

<https://www.virus.org/default-password/>

Abcom PDF Password Cracker

Brute-Force Password Guessing

Administrator Password Guessing

Manual Password Cracking Algorithm

Automated Password Cracking Algorithm

Performing Brute-Force Automated Password Guessing

Automated Password Guessing Brute-Force Tools

NAT

Smbbf (SMB Passive Brute-Force Tool)

SMBCrack

L0phtCrack

Microsoft Authentication
PwDump2 and PwDump3
RainbowCrack
KerberosCrack
John the Ripper (JtR)
Password Sniffing
Password Cracking Tools
LCP
Ophcrack
CrackMapExec
Access PassView
Asterisk Logger
Password Cracking Countermeasures
Best Practices for the Safe Keeping of LAN Manager Hashes in the SAM Database
Disabling LM Hashes
Syskey Utility
AccountAudit
Keyloggers and Spyware
Keystroke Loggers
SC-KeyLog
Revealer Keylogger
Handy Keylogger
Ardamax Keylogger
Powered Keylogger
Elite Keylogger
Quick Keylogger
See Keylogger Tools Section For More Keyloggers
Keylogger and Spyware Countermeasures
Keylogger and Spyware Countermeasure Tools
PrivacyKeyboard
Advanced Anti-Keylogger
SpyHunter
Spy Sweeper
Spyware Terminator
WinCleaner AntiSpyware
Hiding Files
Introduction to Rootkits
Rootkits
Fu
AFX Rootkit
Nuclear
Vanquish
Steps for Detecting Rootkits
Rootkit Detection Tools
Rootkit Countermeasures
Creating Alternate Data Streams
Creating NTFS Streams
NTFS Stream Manipulation
NTFS Stream Countermeasures
NTFS Stream Detectors

NTFS Stream Tool
USB Dumper
Steganography
Process of Hiding Information in Image Files
Least-Significant-Bit Insertion in Image Files
Masking and Filtering Image Files
Algorithms and Transformation
Stego Tools
Stego Detection
Steganalysis Tools
Covering Tracks
Disabling Auditing
Clearing the Windows Event Log
Clean Up Tools
ELSave
WinZapper
Evidence Eliminator
Traceless
Tracks Eraser Pro
ZeroTracks
Chapter Summary
Recommended Reading and Resources
Chapter X. Desktop and Server Vulnerabilities
Chapter Objectives
Key Terms
Windows OS Vulnerabilities
Windows File Systems
Windows Internals
Windows Protocols
Remote Procedure Call (RPC)
NetBIOS (Network Basic Input/Output System)
Server Message Block (SMB)
Common Internet File System (CIFS)
Null Sessions
Web Services
Chapter Summary
Recommended Reading and Resources

Chapter X. Footprinting and Social Engineering
Chapter Objectives
Key Terms
Web Tools for Footprinting
Conducting Competitive Intelligence
Footprinting Techniques
Using Email Addresses
Using HTTP Basics
Using Other Methods to Gather Information
Using Domain Name System (DNS) Zone Transfers
Chapter Summary
Recommended Reading and Resources

Chapter X. Social Engineering

Chapter Objectives

Key Terms

Introduction to Social Engineering

The Art of Shoulder Surfing

The Art of Dumpster Diving

The Art of Piggybacking

Phishing

Chapter Summary

Recommended Reading and Resources

Chapter X. Port Scanning

Chapter Objectives

Key Terms

Introduction to Port Scanning

Types of Port Scans

Using Port Scanning Tools

Nmap (Network Mapper)

Nessus

OpenVAS (Greenbone)

eEye Retina

Conducting Ping Sweeps

Ping Sweep Tools

Fping

Hping2/Hping3

Crafting IP Packets

Understanding Scripting and Scripting Basics

Chapter Summary

Recommended Reading and Resources

Chapter X. Computer Programming for Ethical Hackers

Chapter Objectives

Key Terms

Introduction to Computer Programming

Learning the C Language

Anatomy of a C Program

Understanding HTML Basics

Creating a Webpage with HTML

Understanding Perl

Background on Perl

Understanding the Basics of Perl

Understanding the BLT of Perl

Object-Oriented Programming Concepts

Component of Object-Oriented Programming

Understanding Python

Python Background

Understanding the Basics of Python

Understanding the BLT of Python

Python Shell

Object-Oriented Programming in Python

Overview of Ruby

Chapter Summary
Recommended Reading and Resources
Chapter X. TCP/IP Networking Concepts
Chapter Objectives
Key Terms
TCP/IP Concepts Review
Overview of the TCP Stack
The Application Layer
The Transport Layer
The Internet Layer
IP Addressing
CIDR Notation
Planning IP Address Deployments
IPv6 Addressing
Overview of Numbering Systems
The Binary Numbering Systems
The Octal Numbering System
The Hexadecimal Numbering System
The Base64 Numbering System
Chapter Summary
Recommended Reading and Resources
Chapter X. Computer Network and Domain Cyberattacks
Chapter Objectives
Key Terms
Introduction to Malicious Software (Malware)
Viruses
Macro Viruses
Worms
Trojan Horses
Spyware
Adware
Ransomware
Protecting Against Malware Attacks
User Security Awareness and Continuous Training
Avoiding Fear Tactics
Intruder Attacks on Networks and Computers
Denial of Service (DoS) Attacks
Distributed Denial of Service (DDoS) Attacks
Buffer Overflow Attacks
Eavesdropping / Man-in-the-Middle (MitM) / Interception
Man-in-the-Middle (MiTM) Attacks
Network Session Hijacking
Addressing Physical Security Concerns
Keyloggers
Behind Locked Doors
Chapter Summary
Recommended Reading and Resources

Chapter X. Domain Network Traffic Analysis

Chapter Objectives

Key Terms

Analyzing Captured Network Traffic: What Does It Mean?

The Five-Layer Internet Protocol Stack

Viewing Packets in Wireshark

Analyzing Packets Collected By Your Firewall

Capturing Traffic on Port 80

pfSense

Chapter Summary

Recommended Reading and Resources

Chapter X. Attack and Defense: Offensive vs. Defensive Cybersecurity

Chapter Objectives

Key Terms

Web Application Attacks

OWASP Top 10 Vulnerabilities

Web Application Security and Protection

Denial of Service (DoS) Attacks

Bandwidth Attacks

Slow and Low Attacks

Legacy

Application Exploration

Buffer Overflow

Heap Spraying

Application Protections and Evasion Techniques

Lateral Movement

Defense in Depth/Defense in Breadth

Security Through Obscurity

Layered Security: Defensible Network Architecture

Chapter Summary

Recommended Reading and Resources

Chapter X. Building and Installing Linux Rootkits

Chapter Objectives

Key Terms

Writing a Linux Kernel Module

Writing the Code

Compiling and Running Your Kernel Module

Modifying System Calls

What are System Calls?

How System Calls Work

Hooking Syscalls

Hooking the Shutdown Syscalls

Hiding Files

The linux_direnstruct

Writing the Hooking Code

Using Armitage to Exploit a Host and Install a Rootkit

Scanning the Network

Exploiting a Host

Installing a Rootkit

The Keylogger

Self-Hiding Module

Chapter Summary
Recommended Reading and Resources
Chapter X. Building Trojan Horses
Chapter Objectives
Key Terms
Case Study: Recreating Drovorub by Using Metasploit
Building the Adversary Server
Building the Victim Client
Updating the Implant
Using the Attacker Agent
Why You Need a Victim Kernel Module
Hiding an Implant in a Legitimate File
Creating a Trojan
Hosting the Trojan
Downloading the Infected File
Controlling the Implant
Evading Antivirus by Using Encoders
The Base64 Encoder
Writing a Metasploit Module
Shikata Ga Nai Encoder
Creating a Windows Trojan
Hiding the Trojan in Windows Minesweeper
Hiding the Trojan in a Word Document (Or Any File)
Creating an Android Trojan
Deconstructing the APK to View the Implant
Rebuilding and Signing the APK
Testing Your Android Trojan
EvilDroid
Writing Your Own Python Implant
How to Obfuscate Implants
Building a Platform-Specific Executable
Chapter Summary
Recommended Reading and Resources
Chapter X. Packet Capturing (PCAP) Network Traffic with ARP Spoofing
Chapter Objectives
Key Terms
How the Internet Works
Packets
MAC Addresses
IP Addresses
ARP Tables
ARP Spoofing Attacks
How to Perform an ARP Spoofing Attack
Detecting an ARP Spoofing Attack
Inspecting ARP Tables
Implement an ARP Spoofer in Python
MAC Flooding
Chapter Summary
Recommended Reading and Resources
Chapter X. Hacking the Cloud, Internet of Things (IoT) and Operational Technology

(OT)

Chapter Objectives

Key Terms

Cloud Computing Overview and Concepts

Cloud-Based Services

Shared Responsibility Mode

Public vs. Private Cloud

Grid Computing

Cloud Architecture and Deployment

Responsive Design

Cloud-Native Design

Cloud Deployment

Dealing with REST

Cloud Container Technologies

Serverless Computing

Common Cloud Threats

Access Management

Data Breach

Web Application Compromise

Credential Compromise

Insider Threat

Internet of Things (IoT)

Fog Computing

Operational Technology (OT)

The Purdue Model

Chapter Summary

Recommended Reading and Resources

Chapter X. Cracking Web Passwords

Chapter Objectives

Key Terms

Authentication

Authentication Methods

Basic Authentication

Digest Authentication

NTLM (New Technology LAN Manager) Authentication

Negotiate Authentication

Certificate-Based Authentication

Forms-Based Authentication

RSA Secure Token

Biometric Password Considerations and Issues

Selecting Passwords

Protecting Passwords

Password Cracking

Computer Password Cracking and Support Tools

Web Password Cracking Tools

Countermeasures

Chapter Summary

Recommended Reading and Resources

Chapter X. Constructing TCP Shells and Botnets

Chapter Objectives

Key Terms

Sockets and Process Communications

The TCP Three-Way Handshake

A TCP Reverse Shell

Assessing the Victim Machine

Scanning for Open Ports

Vulnerable Service Exploitation

Writing a Reverse Shell Client

Writing a TCP Server That Listens for a Client

Loading a Reverse Shell onto a Metasploitable Server

Bots and Botnets

A Multi-Client Botnet

SYN Stealth Scans

Detecting XMAS Tree Scans

Chapter Summary

Recommended Reading and Resources

Chapter X. Cryptographic Attacks

Chapter Objectives

Key Terms

Functions of Cryptography

History of Cryptography

The Enigma

Cryptographic Algorithms Introduction

Symmetric Encryption

Symmetric Key Encipherment

Substitution Cipher

Vernam Cipher (One-Time Pad (OTP))

Transposition (Permutation) Cipher

The Exclusive OR (XOR) Function

Symmetric Key Cryptographic Traits

Data Encryption Standard (DES)

Triple DES

The Advanced Encryption Standard (AES)

The Blowfish Algorithm

The Twofish Algorithm

The IDEA Cipher

RC4/RC5/RC6

Rivest Cipher

Asymmetric Encryption

RSA (Rivest-Shamir-Adelman)

Diffie-Hellman (DH)

El Gamal

Elliptic Curve Cryptography (ECC)

Hashing

Digital Signatures

Hash Functions

Developing a Digital Signature

The U.S. Digital Signature Standard (DSS)

Message Digest (MD) 5

Steganography

Digital Certificates
Rjindael
Public Key Infrastructure (PKI)
Public Key Cryptosystems
One-Way Functions
Public Key Algorithms
RSA (Rivest-Shamir-Adelman)
El Gamal
Elliptic Curve (EC) and Elliptic Curve Cryptography (ECC)
Summaries of Public Key Cryptosystems and Approaches
Trust Models
Single-Authority Trust
Hierarchical Trust
Web of Trust
Public Key Certificates
Digital Certificates
Certificate Authorities and PKI
Certificate Revocation Lists (CRLs)
Cryptanalysis
Managing Encryption Keys
Email Security and Digital Signatures
Electronic Transaction Security (ETS)
Wireless Network Security
Wireless Hacking Tools
Protocols, Applications, and Attacks
Encryption Cracking and Tools
Weak Encryption
Encryption Cracking Tools
Chapter Summary
Recommended Reading and Resources
Chapter X. DoS and DDoS Attacks and Hacks
Chapter Objectives
Key Terms
Introduction to Denial of Service (DoS) and Distributed DoS (DDoS) Attacks
Types of DoS and DDoS Attacks
Ping of Death
Smurf and Fraggle
LAND Attack
SYN Flood
Tools to Execute a DoS Attack
Datapool
Jolt2
Hgod
Other Tools
Detecting DoS Attacks
Appliance Firewalls
Host-Based Intrusion Detection System (HIDS)
Signature-Based Network Intrusion Detection System (NIDS)
Network Anomaly Detectors
Preventing DoS Attacks

OS and System Hardening
Network Hardening
Application Hardening
Tweaking Policies on Intrusion Detection Systems (IDSs)
Chapter Summary
Recommended Reading and Resources

Chapter X. Footprinting and Network Scanning

- 64.1 Define the term footprinting
- 64.2 Describe the information gathering methodology
- 64.3 Describe competitive intelligence
- 64.4 Describe Open-Source Intelligence (OSINT)
- 64.5 Understand DNS Enumeration
- 64.6 Understand WHOIS, ARIN Lookup
- 64.7 Identify different types of DNS records
- 64.8 Understand how traceroute is used in footprinting
- 64.9 Understand how email tracking works
- 64.10 Understand how web spiders and crawlers work

Chapter X. Enumeration and System Hacking

Chapter Objectives

Key Terms

Introduction to Enumeration

Windows Enumeration

Windows Security

NetBIOS and LDAP Enumeration

NetBIOS and LDAP Enumeration Tools

SNMP Enumeration

Linux and Unix Enumeration

NTP Enumeration

SMTP Enumeration

DNS Enumeration

System Hacking

Nontechnical Password Attacks

Brute-Force Password Guessing

Automated Brute-Force Password Guessing

Password Sniffing

Password Spraying

Credential Stuffing

Keylogging

Privilege Escalation Tools

Exploiting an Application

Exploiting a Buffer Overflow

Pwning the Box

Windows Authentication Types

Cracking Windows Passwords

Linux Authentication and Passwords

Cracking Linux Passwords

Hiding Files and Covering Tracks

Rootkits

File Hiding

Chapter Summary
Recommended Reading and Resources
Chapter X. Exploitation
Chapter Objectives
Key Terms
Fuzzing for Zero-Day Vulnerabilities
Case Study: Exploiting the Heartbleed OpenSSL Vulnerability
Creating an Exploit
Writing a Client “Hello” Message
Reading and Understanding Server Responses
Crafting a Malicious Heartbeat Request
Reading the Leaked Memory Contacts
Writing the Exploit
Putting It All Together
Introduction to Fuzzing
A Simplified Example of Fuzzing
Fuzzing Web Protocols
Fuzzing an Open-Source Project
Implementing Your Own Concolic Execution Engine
Creating and Writing Your Own Fuzzer
American Fuzz Lop
Symbolic Execution
A Symbolic Execution of the Test Program
Limitations of Symbolic Execution
Dynamic Symbolic Execution (DSE)
Using DSE to Crack a Passcode
Creating an Executable Binary
The Angr Program
Installing and Running Angr
Chapter Summary
Recommended Reading and Resources
Chapter X. Post-Exploitation
1.
Chapter X. Gaining Access: Initial Breach Attempt
1.
Chapter X. Maintaining Access (Foothold) and Persistence
1.

Chapter Covering Tracks: Clean Up and Exit Strategies
1.
Chapter X. Evading IDS, Firewalls, and Honeypots
1.
Chapter X. Hacking Web Applications
1.
Chapter X. Hacking Web Servers and Databases
1.

Chapter X. Malware and Friends
1.
Chapter X. Vulnerability Research, Analysis, and Assessment

Chapter Objectives

Key Terms

Vulnerability Research, Analysis, and Assessment Overview

Initial Discovery of Vulnerabilities

Reverse Engineering

Vulnerability Categories

Insufficient Input Validation Vulnerabilities

Cryptographic Vulnerabilities

Configuration Vulnerabilities

TCP/IP Protocol Vulnerabilities

Authentication Vulnerabilities

Authorization Vulnerabilities

Availability Vulnerabilities

Hardware Vulnerabilities

Vulnerability Tracking and Rating

Common Vulnerabilities and Exposures (CVE)

Common Vulnerability Scoring System (CVSS)

STIXX

TAXII

Common Weakness Enumeration (CWE)

Chapter Summary

Recommended Reading and Resources

Chapter X. Documentation and Reporting

1.

Chapter X. Information Security

1.

Chapter X. Hacking Telecommunications (Telecom) Networks

1.

Chapter X. Networking 101: Basics of Computer Networking

Chapter Objectives

Key Terms

Introduction to Computer Networks

Ethernet

Ethernet (IEEE Standard 802.3)

Token Ring (802.5 and used extensively by IBM)

Token Bus (802.4, intended for manufacturing plants)

Asynchronous Transfer Mode (ATM)

The technology of Asynchronous Transfer Mode (ATM) was developed in the telephone and telecommunications (Telecom) industry in the 1980s at major telephone research laboratories. The goal was to develop a networking technology that could carry an integrated mix of traffic (voice, video, data). At one point, there were two competitors to be the technology of choice: Synchronous Transfer Mode (STM) and ATM. Asynchronous Transfer Mode was the eventual winner.

Multiprotocol Label Switching (MPLS)

The idea behind Multiprotocol Label Switching (MPLS) is simple. In datagram switching, each packet is treated as an independent element by routers. If one implements a Differentiated Services architecture, each independent packet is

treated according to a policy specifically for its service class only. In MPLS, on the other hand, the basic unit is a “flow.” Packets belonging to a given source destination flow within an MPLS network that has labels appended to the packet that is used by routers along specified routing paths to relay the packet from router-to-router, hop-to-hop.

Advanced Encryption Standard (AES)

The Advanced Encryption Standard (AES) is the encryption standard approved in 2000 under the auspices of the US government, originally for civilian cryptographic use. In 2003, the United States government approved the use of AES for classified and secret information. Versions of AES for 192bit and 256bit keys are approved for Top Secret information. The National Institute of Standards and Technology (NIST), which led the three-year approval process for AES, has certified in excess of 1000 products incorporating AES.

Chapter X. Network Traffic Manipulation

Chapter Objectives

Key Terms

Network Traffic Sniffing

tcpdump

Wireshark

Network Traffic Interception

Hub vs. Switch

ARP Poisoning

Arpspoof

Blind and Reverse Shell Using Netcat

Overview

Enter the Netcat

Bind Shell

Reverse Shell

Chapter Summary

Recommended Reading and Resources

65 Our office address

Tools and Resources

Keyloggers

Snake Keylogger: Also known as 404 Keylogger, this prominent information-stealing spyware spreads via phishing emails and targets system configurations, credentials, and banking details.

Agent Tesla: A highly advanced Remote Access Trojan (RAT) and keylogger combo that steals data from web browsers, email clients, and FTP servers.

Olympic Vision: A low-cost commercial keylogger frequently used in Business Email Compromise (BEC) attacks to hijack corporate emails.

Ardamax Keylogger: A long-standing keylogger that captures keystrokes, takes screenshots, and records microphone audio. While sold under the guise of a “monitoring utility,” it is often utilized maliciously.

SC-KeyLog

Revealer Keylogger

Handy Keylogger

Ardamax Keylogger
Powered Keylogger
Elite Keylogger
Quick Keylogger
Spy Keylogger
Perfect Keylogger
Invisible Keylogger
Actual Spy
Spytector
Invisible KeyLogger Stealth
66 Ghost Keylogger
67 KeyGhost Hardware Keylogger
68 007 Spy Software
69 Spector Pro
70 RemoteSpy
71 Spytech SpyAgent
72 SpyBuddy
73 Stealth KeyLogger
74 AceSpy
75 Keystroke Spy
76 Desktop Spy
77 Activity Monitor
78 Wiretap Professional
79 eBlaster
80 Stealth Recorder
81 Stealth Website Logger
82 Digi-Watcher Video Surveillance
83 Phone Spy
84 Print Monitor Pro
85 Stealth Email Redirector
86 FlexiSpy
87 PC PhoneHome
hhhh
Add files or folders here
/media/insert-embed/dropbox

YouSay Tomato, I Say Tomahto (Red and Green Apples)

Federal Active Directory (AD) environments face fundamentally different security and compliance requirements than commercial ones. While both sectors are targeted by attackers, federal assessments reveal distinct vulnerabilities that are shaped by rigid regulatory frameworks like FedRAMP and the NIST SP 800-53.

Regulatory and Architectural Differences

88 Compliance and Agility: Federal FICAM networks heavily prioritize strict compliance with NIST and FBI CJIS Security Policy. Commercial Active Directory(AD) environments prioritize rapid feature deployment and operational flexibility, ease-of-use, often leading to technical debt.

89 Air-Gapping and Segmentation: Federal security assessments frequently feature highly segregated, segmented, isolated, or otherwise disconnected

(air-gapped) environments to protect SIPRNet classified information systems. Commercial environments tend to embrace highly integrated hybrid-cloud and Software-as-a-Service (SaaS) infrastructures.

90 Legacy Constraints: Federal agencies are often burdened with legacy enterprise software that mandates the use of less secure, deprecated protocols, like NTLM and Unconstrained Delegation.

Common Vulnerabilities and Findings in Federal Assessments

Federal Active Directory Security Assessments (ADSA) routinely highlight several systemic flaws as defined by the CISA / NSA Top Ten Cybersecurity recommendations:

91 Excessive Domain Admin Rights

Audits regularly find over-provisioned "Domain Admin" accounts assigned to staff, contractors, and service accounts. Federal guidance heavily stresses strict adherence to the Principle of Least Privilege (PoLP) and Tiered Administration models to prevent lateral movement.

92 Legacy Protocol Abuse

Federal networks are often slower to deprecate legacy authentication protocols like NTLMv1 and LAN Manager (LM). Federal red team engagements frequently exploit this using Pass-the-Hash (PtH) or NTLM relay attacks to escalate domain privileges.

93 Active Directory Certificate Services (AD CS) Misconfigurations

Federal enterprises widely use AD CS for smart-card and hardware-based PIV/CAC authentication. Penetration testing frequently identifies vulnerable certificate templates (e.g., ESC1 or ESC8) that allow threat actors to forge administrative certificates.

94 Unconstrained Kerberos Delegation

Found in older agency applications, this misconfiguration permits a compromised service account to impersonate an administrator and request Kerberos Ticket Granting Tickets (TGT) to take over Domain Controllers.

95 Stale Accounts and Tier 0 Accounts

Audit findings frequently spotlight orphaned, inactive administrative accounts and poorly monitored Tier 0 assets, offering attackers an easy vector to maintain long-term, stealthy persistence.

primary federal authorities governing information security and Active Directory architectures: